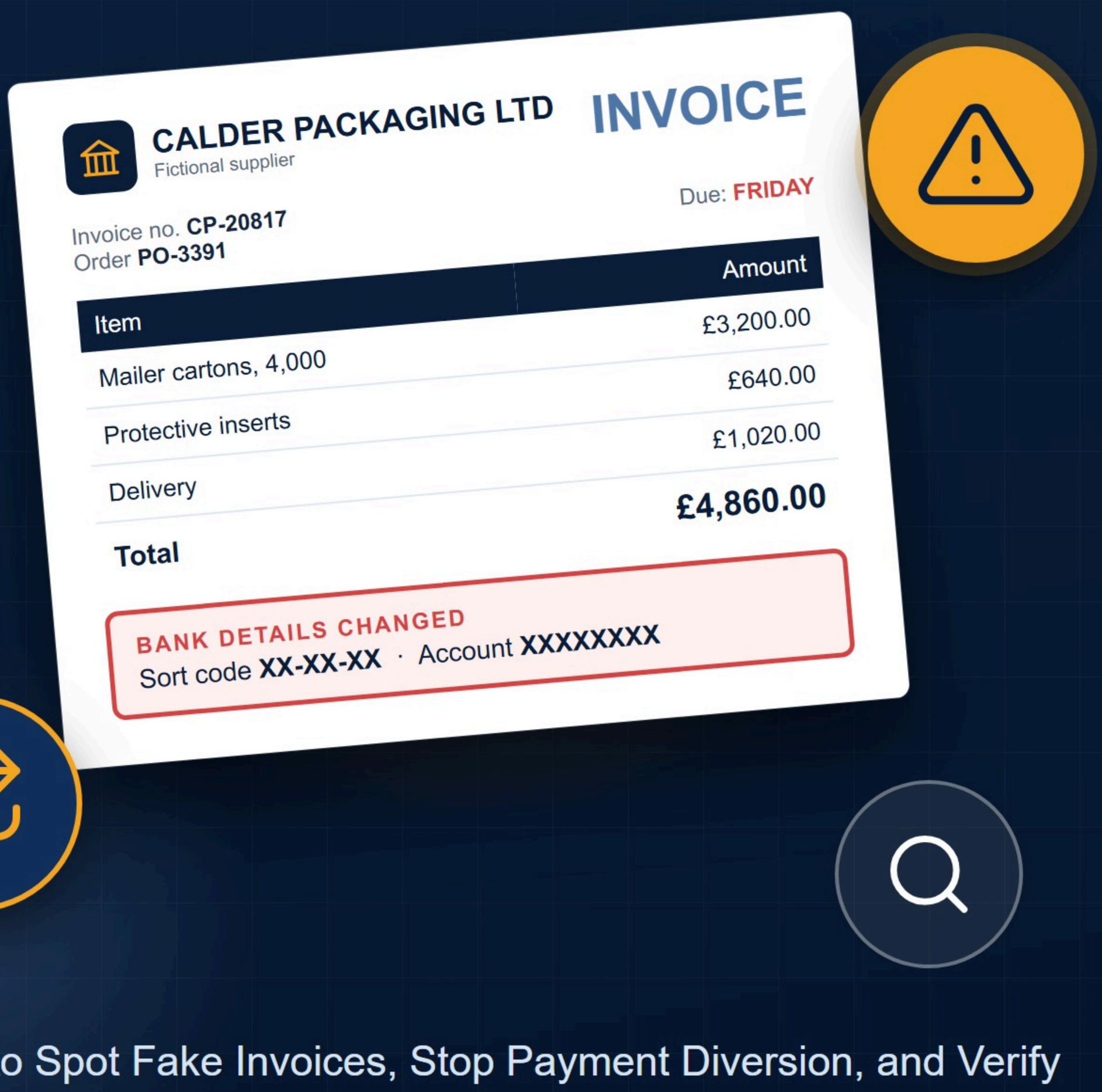
THE AI

INVOICE SCAM

SURVIVAL GUIDE



How to Spot Fake Invoices, Stop Payment Diversion, and Verify Supplier Bank-Detail Changes Before You Lose Money

ZIRLANDIA MILKOVIC

THE AI

INVOICE SCAM SURVIVAL GUIDE

How to Spot Fake Invoices, Stop Payment Diversion, and Verify Supplier Bank-Detail Changes Before You Lose Money

ZIRLANDIA MILKOVIC

The AI Invoice Scam Survival Guide
How to Spot Fake Invoices, Stop Payment Diversion, and Verify Supplier Bank-Detail Changes Before You Lose Money

© 2026 Zirlandia Milkovic. All rights reserved. No part of this book may be reproduced without written permission, except for brief quotations in reviews.

First edition, 2026. Research cut-off: 28 October 2026. British English. Companion resource: GDPRGard.eu.

This book is practical guidance, not legal, financial or banking advice. All examples, businesses and people in worked scenarios are fictional.

Contents

START HERE

Educational Disclaimer 4
Introduction: Why Invoice Fraud Belongs in Every Risk Plan 5
Who This Book Is For 7
How to Use This Book 8
Before You Pay: The One-Page Checklist 9

CHAPTERS

1. The Invoice That Looked Perfect 10
2. Know the Main Invoice Scams 14
3. How AI Changes the Fraud Landscape 20
4. The Golden Rule: Verify Before You Pay 24
5. The Supplier Bank-Detail Change Procedure 30
6. Build a Payment Process That Is Difficult to Manipulate 37
7. Warning Signs That Deserve a Second Look 42
8. What to Do If You Have Already Paid 47
9. When Customer or Employee Data Is Also Exposed 51
10. The Small Business Anti-Fraud Policy 56
11. Your 30-Day Payment Protection Plan 60
12. Five Case Files 64

APPENDICES

Appendix A: Supplier Bank-Detail Change Checklist 69
Appendix B: Before-You-Pay Checklist 71
Appendix C: Suspected Invoice Fraud Response Flow 73
Appendix D: Payment Approval Matrix 75
Appendix E: Fraud Incident Log 77
Appendix F: Staff Verification Scripts 78
Appendix G: Knowledge Check 80
Appendix H: Staff Training Exercise 83
Appendix I: Quarterly Payment-Control Review 85

BACK MATTER

Glossary 86
A Note on GDPRGard.eu 87
About the Author 88
Notes and Sources 89

Educational Disclaimer

This book is practical, educational guidance for small businesses. It is not legal, financial, banking, insurance or data-protection advice, and it does not create a professional relationship between the author and the reader.

Payment fraud rules, bank procedures, reporting routes and data-protection duties differ by country, bank, payment method and circumstance. They also change. Check the current position with your bank, your accountant or a qualified adviser before relying on anything here for a decision that matters.

Following the procedures in this book may reduce your risk. It cannot guarantee that a fraud will be prevented, that a bank will be able to recover a payment, or that you will meet any legal obligation. Templates are starting points to adapt, not finished policies.

Every business, person and email address used in a worked example is **fictional** and is labelled as such. Any resemblance to a real organisation is coincidence. Where the book states a fact, it is sourced in the notes at the back; where it gives a recommendation, it says so.

Introduction: Why Invoice Fraud Belongs in Every Risk Plan

Most small businesses have a plan for a broken laptop or a missed delivery. Far fewer have a plan for the moment a trusted supplier appears to say, "Our bank details have changed."

That sentence is the heart of this book, because it is how one of the most common kinds of business payment fraud begins. The invoice looks right. The logo is right. The email arrives in the same thread as last month's genuine message. Someone in the office is busy, the due date is close, and the payment goes out. A few days later the real supplier asks why they have not been paid.

Nothing in that story needed advanced hacking. It needed a believable message and an ordinary process that trusted what it was shown.

The UK's National Cyber Security Centre (NCSC) describes the pattern plainly: criminals send emails tailored to your organisation, pose as a contact you normally deal with, and ask you to pay money into a different bank account.[1] Europol's published threat assessments describe the same family of crime, which it also calls payment order fraud, CEO fraud and business email compromise, as a long-running concern for organisations across Europe.[2]

What has changed

Two things make this the right moment to take it seriously.

First, **writing is cheaper to fake than it used to be.** Clumsy grammar and awkward phrasing were once useful clues. AI writing tools can now produce fluent, professional messages in any language, and in some circumstances criminals can imitate a voice or a face. This book covers that honestly and without alarm, because the useful lesson is not "learn to spot AI". It is "stop treating polish as proof".

Second, **payments move faster.** Many UK and European bank transfers arrive within seconds. Speed is convenient for you and for a fraudster, and it shortens the time in which anyone can intervene.

What this book will and will not do

It will give you a repeatable system built around three ideas:

1. **Never rely on how a payment instruction looks or who it seems to come from.**
2. **Verify changes and unusual requests through a channel you already trust.**
3. **Make the safe route the easy route**, with simple approvals, a written record, and a plan for the day something goes wrong.

It will not turn you into a cybersecurity specialist, and it does not ask you to buy software. Most of what follows is procedure: who checks what, in what order, and what they write down.

It also will not promise you can never be defrauded. No procedure can. The aim is to make a fraud harder to complete, quicker to notice, and less likely to go unchallenged.

A note on facts, recommendations and fiction

Throughout the book you will see four kinds of material, and I have tried to keep them apart:

- **Verified facts**, with a numbered note pointing to the source, such as official guidance from the NCSC, the Information Commissioner's Office (ICO) or Europol.
- **Practical recommendations**, which are my suggestions for small businesses. They are sensible, but they are not legal requirements.
- **Fictional scenarios**, labelled *Fictional*, used only for teaching. No real company, loss or incident is portrayed.
- **Jurisdiction-specific rules**, such as reporting routes and breach-notification duties, flagged so you can check the version that applies to you.

I have deliberately avoided quoting loss statistics. Published figures vary by year, definition and source, and a number that was right when it was printed can mislead a year later. If you want current figures, UK Finance and national police services publish them, and the notes list where to start.

Who This Book Is For

You do not need a finance or technology background. This book is written for people who pay suppliers and cannot afford a dedicated fraud team:

- owners and directors of small and medium-sized businesses
- freelancers and independent professionals
- bookkeepers, finance assistants and accounts-payable staff
- office and operations managers
- e-commerce businesses and small agencies
- start-ups with few internal controls
- any business that pays suppliers, contractors, freelancers or international vendors

If you are the only person who both receives invoices and sends payments, Chapter 6 gives proportionate alternatives to having a second pair of hands.

Plain-English promise. Specialist terms are explained the first time they appear, and each has a short entry you can find again in the glossary at the back.

How to Use This Book

You can read it straight through in an evening, or use it as a manual. Either way, I suggest this order:

1. **Read the one-page checklist** that follows this section. If you only do one thing, use it before your next payment.
2. **Read Chapters 1 to 4** to understand the threat and learn the PAUSE method.
3. **Read Chapter 5 closely.** The supplier bank-detail change procedure is the most useful single process in the book. If I could recommend only one protection to any business, this would be it.
4. **Work through Chapter 11**, the 30-day plan, with the toolkit open beside you.
5. **Keep Chapter 8 and the "First 30 Minutes" checklist** somewhere everyone can find them, ideally printed and saved on a shared drive.

The toolkit at the back (Appendices A to I) is designed to be used on its own. Copy each page into a document or spreadsheet, replace the placeholders in square brackets, and make it yours.

> **Icons used in this book**
>
> **The rule** boxes hold the single idea to remember from a section. **Fictional** labels mark teaching scenarios. **Check** boxes tell you exactly what to verify.

Before You Pay: The One-Page Checklist

Use this before releasing any payment. It takes about two minutes. The full version, with space to sign, is Appendix B.

- ☐ **Do I know this supplier?** They are in our supplier records and I can say what they supplied.
- ☐ **Does the invoice match reality?** There is a purchase order, contract or delivery confirmation, and the amount and description agree.
- ☐ **Is it new or duplicated?** The invoice number is not one we have already paid; the supplier's reminder is not for something already settled.
- ☐ **Are the bank details the ones we already hold?** The sort code, account number or IBAN, and account name match our records.
- ☐ **Has anything changed?** A new account, new payee, new payment method, new contact or new deadline means **stop and run the bank-detail change procedure** (Chapter 5).
- ☐ **Is anyone hurrying or hiding it?** Urgency, secrecy or "skip the usual approvals" are reasons to slow down, not speed up.
- ☐ **Did I verify through a channel I already trust?** I used a number or contact from our own records, not one in the message.
- ☐ **Has the right second person approved it?** Approval follows our payment policy, not a quick reply in the same email thread.
- ☐ **Did I write down what I checked?** Name, date, method, outcome.

> **The rule:** If a payment instruction is new, changed, urgent or unusual, a polished invoice is not enough. Verify it independently before you pay.

CHAPTER 1

The Invoice That Looked Perfect



Fictional scenario: Bramwell Print Studio

> **Fictional.** Bramwell Print Studio, Calder Packaging Ltd and every person, address and figure below are invented for teaching. They are not real businesses or incidents.

Bramwell Print Studio is a nine-person print business. Every month it buys cartons and mailers from Calder Packaging Ltd, a supplier it has used for four years. Priya, the office manager, receives the invoices. Marcus, the owner, approves payments on the bank app.

On Thursday morning an email lands in the same thread as last month's genuine invoice:

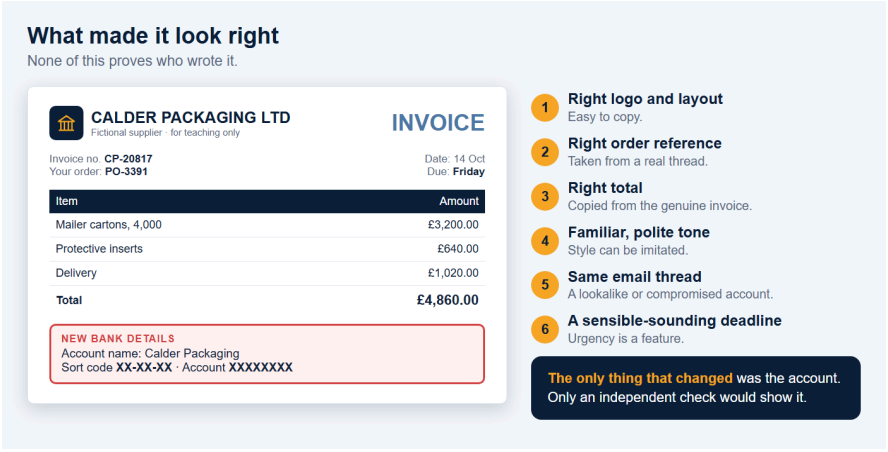
> **From:** Dana Whitcombe accounts@calderpackagng.example **Subject:** RE: Invoice CP-20817, updated payment details
>
> Hi Priya, apologies for the confusion. We have changed banks following an internal audit. Please find attached the invoice for this month's order, with our new account details. As our year-end is Friday we need payment to clear by close of business tomorrow, so that it posts to the right period. Please do not use the old account, as it is being closed. Many thanks, Dana

The attached invoice has the right logo, the right order reference and the right total of £4,860.00. The only difference is the account. Priya forwards it to Marcus with a note: "Calder have changed bank. Needs paying by tomorrow."

Marcus knows Dana. The wording is polite and familiar. The thread goes back months. He is between meetings and the supplier is a reliable one. He updates the supplier record and pays that afternoon.

On Tuesday the real Calder Packaging phones to ask why the invoice has not been paid.

Look closely at the sender address above: *calderpackagng*, with the "i" missing. In a busy inbox, on a phone screen, it is easy not to see. But the missing letter is not the real lesson. If the address had been perfect, the process would still have failed, because **nobody checked the change with Calder through a route the fraudster did not control.**



What made the invoice look right

What went wrong, step by step

Moment	What happened	The weakness
Email arrives	In a familiar thread, from a near-identical address	Familiarity treated as proof
Priya reads it	Passes it on with the details unchanged	No flag for "bank details changed"
Marcus approves	Updates the record and pays on the same day	One person both changed and approved
Deadline	"Clear by close of business tomorrow"	Urgency removed time to check
Verification	None	The only contact used was the email itself

Nobody was careless in the everyday sense. They were doing what a trusting, busy team does. The failure was in the **process**: it allowed a bank-detail change to reach the payment system on the strength of an email alone.

What is invoice fraud?

Invoice fraud is any scheme that tricks a business into paying money it does not owe, or paying it to the wrong person, by using false or altered invoices or payment instructions. It takes several shapes, which Chapter 2 covers.

Two terms are worth fixing early:

- **Payment diversion** (also called mandate fraud, or an *invoice redirection scam*) is when a genuine invoice is paid, but the money is sent to an account controlled by a criminal because the bank details were falsified. The supplier did supply the goods. They simply never receive the money.
- **Business email compromise (BEC)** is when criminals use email, either by impersonating a trusted person or by taking over a real mailbox, to trick staff into sending money or information. The NCSC calls this business payment fraud, and notes it often involves a request to pay into a different bank account.[1]

> **Mandate** here does not mean a legal mandate. It is old banking language for the standing instruction that tells a bank who to pay. "Mandate fraud" means that instruction was tampered with.

Why a legitimate-looking document proves nothing

A logo, a layout and a plausible invoice number are all easy to copy. Fraudsters can obtain real invoices from a compromised mailbox, from a supplier's published contracts, or from a document someone has shared carelessly, and then change a single line.

Three things look reassuring and are not evidence:

1. **Appearance.** Professional design is cheap to reproduce.
2. **Familiarity.** If a real mailbox has been taken over, the message may arrive from the genuine address, in the genuine thread, in the genuine voice.
3. **History.** "We have always paid them like this" tells you what was true last month. It tells you nothing about who wrote today's email.

What does count is **independent verification**: asking the supplier, through a contact route you already hold and trust, whether they sent this instruction.

Why every size of business is a target

Fraudsters do not need to know you. They need an invoice-shaped hole in a process. Small businesses can be attractive because approvals are informal, one person can often do everything, and the owner is busy. Larger businesses are targeted too, because they pay more and have more suppliers.

Suppliers are also exposed. A fraudster may attack your supplier's mailbox in order to reach you. A criminal may know which businesses buy from which suppliers because that information is public in contracts, websites, social media posts or tender records.

How simple controls interrupt the scam

At Bramwell, any one of these small habits would have broken the chain:

- A rule that **no bank-detail change is applied until someone has phoned the supplier on a number already held in the records.**
- A rule that **the person who receives the change request cannot also approve the payment.**
- A rule that **urgent deadlines trigger more checks, not fewer.**
- A **first-payment review** after any change.

None of these costs money. Each takes minutes. That is the whole philosophy of this book.

Five lessons from Bramwell

1. **A familiar email thread is not a verified identity.**
2. **A change to bank details is a different event from an ordinary invoice**, and needs its own process.
3. **Urgency is a feature of the scam**, not a reason to skip checks.
4. **Verify through a route you already hold**, never through contact details in the suspicious message.
5. **Separate the people who change records from the people who approve payments**, and write down what was checked.

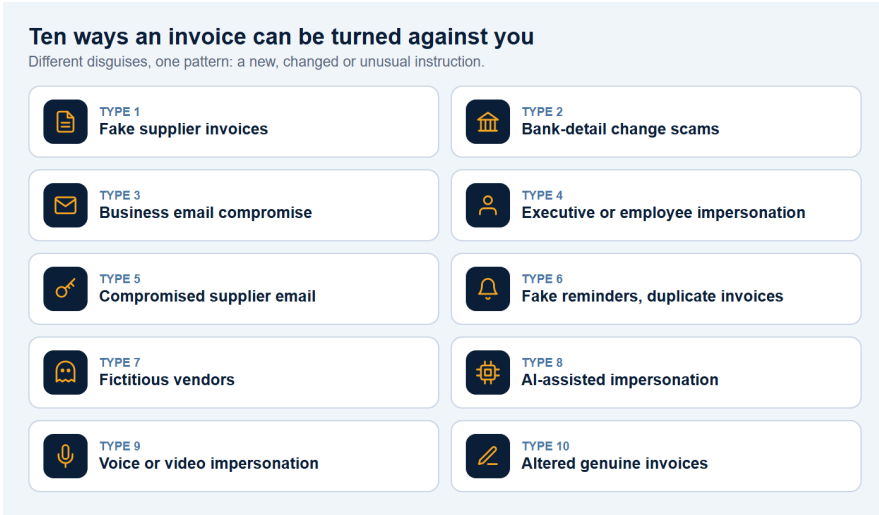
> **The rule:** Appearance and familiarity are not verification. Only an independent check is.

CHAPTER 2

Know the Main Invoice Scams



Fraudsters borrow from the same toolkit again and again. If you recognise the pattern, you recognise the scam, whatever the wording. This chapter walks through ten types in plain English. Each has a **fictional example**, the **warning signs**, the **control** that interrupts it, and the **correct response**.



Ten ways an invoice can be turned against you

Fraudulent invoice, or genuine invoice with false instructions?

Before the list, one distinction matters because it changes what you check.

	Fraudulent invoice	Genuine invoice with altered payment instructions
What is false?	The whole thing: the debt does not exist	Only the bank details or payment instructions
Is there a real supplier relationship?	Not for this invoice	Yes

	Fraudulent invoice	Genuine invoice with altered payment instructions
What a good check reveals	No order, no delivery, no matching record	Order and delivery match, but the account differs
Typical control	Match to purchase order or delivery	Verify the bank-detail change independently

Both can arrive looking identical. You need both checks: *did we order this?* and *are these the right bank details?*

1. Fake supplier invoices

A criminal invoices you for goods or services you never ordered, hoping the invoice is simply paid.

> **Fictional.** An invoice arrives from "Northway Office Supplies" for £1,240 of toner. Nobody remembers ordering toner. The invoice references "your recent order". It is paid because the amount is below the usual approval limit.

- **Warning signs:** no purchase order; vague descriptions ("services rendered"); a supplier you cannot place; amounts just under an approval limit.
- **Control:** three-way match of invoice, purchase order and delivery; an approved-supplier list.
- **Correct response:** do not pay. Ask whoever is named as the orderer. If you cannot confirm an order, contact the supplier using details you find yourself, not the invoice's, and keep the invoice.

2. Supplier bank-detail change scams

A message, apparently from a genuine supplier, says their bank details have changed. Future payments, or a specific invoice, are to go to the new account. This is the scam Chapter 5 is built to stop.

> **Fictional.** A landscaping contractor emails: "We've moved to a business account at a new bank. Please update your records and send this month's payment here."

- **Warning signs:** a change nobody asked for; a request to update records "going forward"; a letter or email rather than a conversation; a reason that sounds administrative (audit, merger, tax, system migration).

- **Control:** the Supplier Bank-Detail Change Procedure (Chapter 5) and Appendix A.
- **Correct response:** do not change the record or pay. Verify with the supplier using trusted contact details already held.

3. Business email compromise

Criminals use email, either by pretending to be someone you trust or by controlling a real account, to get you to send money or information. Chapter 1 gave the definition.[1] The next three types are variants.

> **Fictional.** An email appears to come from your accountant, asking you to "settle the HMRC liability today" to a named account.

- **Warning signs:** a request outside the normal channel; pressure to act today; details that differ from earlier payments to the same payee.
- **Control:** an agreed route for payment requests; independent confirmation of unusual ones.
- **Correct response:** phone the person on a number you already hold.

4. Executive or employee impersonation

A fraudster pretends to be the owner, a director or a colleague and asks finance staff to make a payment, often an unusual one, often urgently, often secretly.

> **Fictional.** "I'm in a meeting and can't talk. I need a £9,500 payment made to a new supplier before 3 pm. Keep this between us until I'm back."

- **Warning signs:** secrecy; the sender is unavailable by phone; a new payee; "I'll explain later".
- **Control:** a written rule that nobody, including the owner, can order an unusual payment without a second check. Make it a rule that protects staff.
- **Correct response:** call the person on their known number, or approach them in person. Escalate if you cannot reach them.

5. Compromised supplier email accounts

A criminal gains access to your *supplier's* mailbox. They read genuine correspondence and then send a perfectly timed message, from the real address, with changed bank details.

> **Fictional.** Your usual contact at a freight forwarder writes from her real address, in the real thread, about the real shipment, asking you to use "our other account" this time.

- **Warning signs:** a sudden change from a genuine address; slight shifts in wording; reluctance to speak by phone; a request that arrives at an unusually helpful moment.
- **Control:** independent verification by phone. The address will not show anything wrong, so address-spotting is not a control here.
- **Correct response:** verify by phone using trusted details. If the supplier confirms they did not send it, tell them promptly: their account may be compromised.

6. Fake payment reminders and duplicate invoices

You receive a "final reminder" for an invoice that is already paid, or a second copy of a genuine invoice with different bank details.

> **Fictional.** "Second reminder: invoice CP-20817 is overdue. Late fees apply. Please pay to the account below." CP-20817 was paid last month.

- **Warning signs:** threats of fees; a changed account; a reminder with no earlier invoice in your records.
- **Control:** duplicate-invoice checks against a paid register; a rule that reminders with new details go through the change procedure.
- **Correct response:** look up the invoice in your own records first. If it was paid, say so and ask the supplier to confirm receipt through a trusted route.

7. Fraudulent invoices from fictitious vendors

A made-up company is set up, sometimes with a plausible website, and sends invoices that look like routine small costs: hosting, directory listings, "compliance" services.

> **Fictional.** "EuroBiz Registry Services" invoices £289 for "annual registration renewal". The invoice looks official and uses language that sounds like a government form.

- **Warning signs:** a supplier never used before; no contract; official-sounding names; urgency tied to "renewal" or "penalties".

- **Control:** new-supplier onboarding checks; a rule that unrecognised suppliers are not paid until the requester is identified.
- **Correct response:** do not pay. Check with whoever manages the service. If a public body or regulator is claimed, find its official contact details yourself.

8. AI-assisted impersonation and social engineering

Here a message is polished, personalised or translated using AI writing tools. **Social engineering** simply means manipulating people into acting, rather than breaking into systems. Chapter 3 treats this realistically: AI may help some attempts, but the scam is the same.

> **Fictional.** A well-written email in your supplier's usual tone, mentioning last week's delivery by name, asks you to use a "new collection account".

- **Warning signs:** the same behavioural signs as ever: urgency, change, secrecy, bypassing the process.
- **Control:** verification does not depend on spotting that AI was used.
- **Correct response:** follow the same independent verification.

9. Voice-cloning and video-impersonation payment requests

Some criminals may imitate a voice or a face on a call or video meeting. This is less common than ordinary email deception, and you should not assume it, but you should know that a familiar voice or face on a screen is no longer proof of identity in a payment request.

> **Fictional.** A voice message that sounds like your director asks you to make an urgent payment to an account "I'll send to you now".

- **Warning signs:** an exceptional transfer; pressure to act now; no written trail; the request arrives through an unusual channel such as a messaging app.
- **Control:** a **call-back** to a number from your records, or an agreed code or question that only the real person would know, set up in advance.
- **Correct response:** end the call, call back on the known number, and tell your manager.

10. Invoice manipulation during legitimate transactions

A criminal who has access to a real mailbox waits for a genuine invoice to be sent, intercepts it, changes the bank details, and forwards it on.

> **Fictional.** You are expecting an invoice from a consultant. It arrives on time, with the right text and the right amount. The account number is not the one on their previous invoices.

- **Warning signs:** the account differs from past invoices; metadata or formatting differs slightly; payment terms have shifted.
- **Control:** compare against bank details already held; treat any difference as a change request.
- **Correct response:** do not pay until the difference is explained by a trusted verification.

The pattern behind all ten

Look back across the list. The facts differ, but nearly every case has the same core:

> a **new, changed or unusual instruction**, delivered with **pressure** or **secrecy**, **bypassing the normal check**.

That pattern is what the rest of this book trains you to spot.

> **The rule:** You do not need to identify the type of scam. You need to notice that something about the payment instruction is new, changed, urgent or unusual, and then verify it.

CHAPTER 3

How AI Changes the Fraud Landscape



Most invoice fraud does not need AI. Fraudsters have been sending convincing fake invoices, taking over mailboxes and impersonating bosses for years, using nothing more than ordinary email and a little research. Europol's published analyses of payment order fraud and business email compromise describe those methods long before today's AI tools were widely available.[2]

So why a chapter on AI? Because it changes *one thing* in a way that matters for how you defend yourself: **it reduces the value of the clues people used to rely on.**

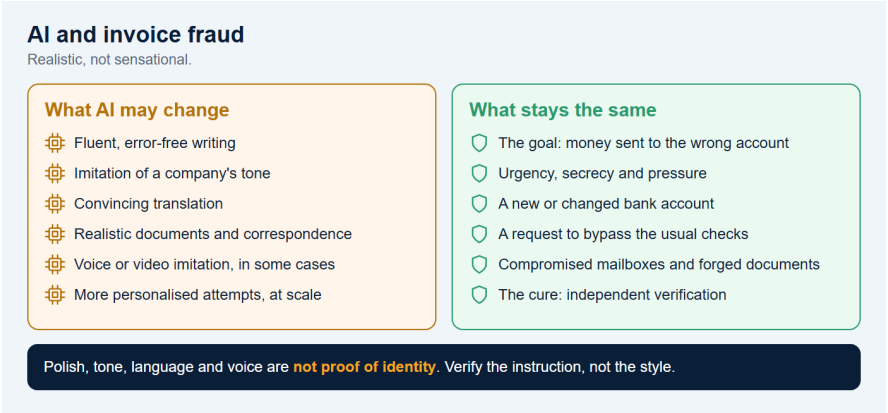
What the evidence says, and does not say

The NCSC's assessment of the impact of AI on cyber threat, published in May 2025, judged that threat actors are almost certainly already using AI to support activities including social engineering, and expected it to make existing methods more effective and efficient rather than to create entirely new types of attack.[4] That assessment is about cyber intrusion in general. It does not give figures for invoice fraud, and it does not assess voice or video cloning in detail.

The honest summary is therefore modest:

- AI **can** help criminals write better, faster, in more languages.
- AI **may** help some criminals personalise attempts and scale them.
- In **some circumstances**, criminals may use synthetic voice or video.
- **Many** invoice scams still rely on ordinary deception, compromised accounts or forged documents.
- There is no reliable way for a busy employee to look at a message and say "this was written by AI".

> **Fictional teaching note.** The scenarios in this chapter are invented illustrations. They do not describe documented incidents.



What AI changes, and what it leaves exactly the same

Six ways AI may assist a fraudster

1. Better grammar and professionalism

Spelling mistakes and awkward phrasing were once a red flag. A writing tool can now produce a flawless, courteous email in seconds. **The absence of errors is no longer reassuring.**

2. Matching a company's communication style

If a fraudster has a few genuine emails, from a leaked mailbox, a public post or a past exchange, a writing tool can imitate tone: formal or chatty, brief or detailed, "Hi Priya" or "Dear Ms Shah". **A familiar style is no longer proof of identity.**

3. Translation

A message that once would have been obviously machine-translated may now read naturally in German, Portuguese or Croatian. This matters for businesses that trade across Europe. **Native-sounding language does not show the sender is who they claim.**

4. Realistic business correspondence

Invoices, purchase-order references, delivery notes and "audit letters" can be generated or edited convincingly. **A document that looks official is not an official document.**

5. Voice or video impersonation, in some circumstances

Synthetic voice and video tools exist, and criminals may use them. A short recording of someone speaking can be enough for some tools to produce a similar-sounding voice. This is not what most businesses face today, and you should not assume that a call or video is fake. But **a familiar voice or a face on a screen should not be your only check on a request to move money.**

6. Scale and personalisation

A criminal who once wrote one careful message can now draft many, each tailored to a different company using public information. **Being a small, unremarkable business does not make you invisible.**

What this means for your defences

If polish, tone, language and even voice can be imitated, you cannot defend by trying to decide whether something *feels* real. Instead, defend by **changing what you rely on**:

Old clue	Why it is weaker now	What to rely on instead
Poor grammar	Tools correct it	Whether the *instruction* is new or changed
Unfamiliar tone	Tools can imitate tone	Whether a trusted contact confirms it independently
Generic greeting	Messages can be personalised	Whether the request fits a real order
Strange accent on a call	Voices can be imitated	A call-back to a number you already hold
Unprofessional document	Documents can be generated	Matching it to your own records

Notice that the right-hand column has nothing to do with AI. That is the point. **Verification works whether or not AI was involved.**

The behavioural warning signs

Whoever or whatever wrote the message, the *behaviour* it asks of you gives it away. Learn these seven. Chapter 7 expands each into a mini guide.

1. **Sudden payment urgency.** "Today." "Before close of business." "The old account is being closed."
2. **Secrecy requests.** "Please keep this confidential." "Don't discuss it with the team."
3. **Unexpected changes to bank details.** Particularly for an established supplier.

4. **Instructions to bypass standard procedures.** "Skip the approval, I'll sign it off later."
5. **A new payment recipient.** A payee your business has never paid.
6. **Requests to split payments or use an unusual transfer method.** Two smaller payments; an international transfer instead of the usual domestic one; a prepaid voucher; a cryptocurrency address.
7. **Claims that normal verification is impossible.** "I'm travelling and can't take calls." "Our phone system is down." "Email me, not call."

Any one of these deserves a pause. Several together deserve a firm no until you have verified.

Don't try to detect AI

It is tempting to look for "AI tells". Resist it, for three reasons:

- **They are unreliable.** Human writers produce stilted text; AI can produce natural text.
- **They change.** A tell that works this year may not work next year.
- **They distract.** Time spent judging style is time not spent calling the supplier.

Spend that time on the call. The conclusion, and the thread of the whole book, is this:

> **The rule:** Convincing writing, familiar phrasing and a familiar-sounding voice are not proof of identity. Verify the instruction, not the style.

CHAPTER 4

The Golden Rule: Verify Before You Pay



Every control in this book comes down to one habit. When a payment instruction is new, changed, urgent or unusual, stop and check it through a route the sender does not control.

To make that habit easy to remember and easy to teach, this chapter gives it a name: **PAUSE.**

PAUSE before you pay

A five-step habit for any new, changed, urgent or unusual payment.

P	**Pause**	Stop when an instruction is unexpected, changed, urgent or unusual.
A	**Assess**	Check the invoice, supplier, amount, PO and bank details against your own records.
U	**Use an independent channel**	Call a number you already held. Never one from the message.
S	**Secure approval**	A second person reviews the evidence and approves.
E	**Evidence**	Record who checked what, who approved, and when.

The PAUSE method

P: Pause

Stop when payment instructions are unexpected, changed, urgent or unusual.

The pause is the most important step because it is the only one that costs nothing. Fraud works by shrinking the gap between reading a message and acting on it. Your job is to put that gap back.

What triggers a pause:

- a new or changed bank account
- a new payee
- an unusual amount or payment method
- a deadline that is much shorter than normal
- a request to keep something private or skip the process
- a change in the way the supplier normally communicates

In practice: don't reply, don't click, don't pay. Move the item to a "needs checking" folder. Tell yourself, and your colleagues, that pausing is **not rude and not a failure**. It is the job.

A: Assess

Check the invoice, the supplier's identity, the payment recipient, the amount, the purchase order and the context.

Ask these questions, in this order:

1. **Did we order this?** Is there a purchase order, contract, quote or delivery confirmation?
2. **Does the amount make sense?** Compare with similar invoices and the agreed price.
3. **Has this invoice been paid before?** Check your paid register.
4. **Are the bank details identical** to those we already hold for this supplier?
5. **Who is asking, and is this how they normally ask?**
6. **What is different about this request?** Spot the difference and name it.

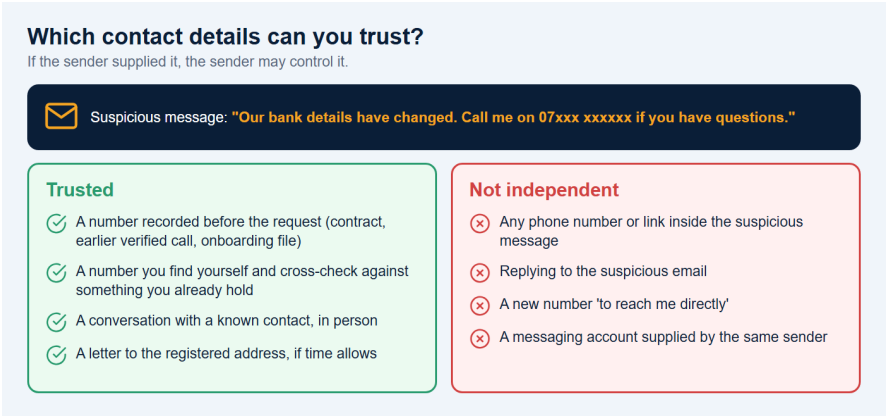
Assessment uses *your own records*, not the message. Treat everything inside the message as a claim until confirmed.

U: Use an independent channel

Contact the supplier through a trusted telephone number or communication method already held in company records, not solely through details supplied in the suspicious message.

This is the step people most often get wrong, so it is worth being precise.

Calling the phone number in the suspicious email is not independent verification. A number, link or "reply to this address" supplied alongside an unexpected bank-detail change may belong to the fraudster. If you call it, the person who answers may be the fraudster, and they will happily confirm.



Trusted and untrusted ways to verify

Trusted sources, in rough order of strength:

- a phone number you recorded **before** this request arrived (from a signed contract, an earlier verified call, your own supplier file)
- a number you find yourself from the supplier's official website, typed in your own browser, not reached by a link in the message (see the caution below)
- a face-to-face conversation or a known contact at the supplier
- a letter to the registered address, if time allows

Caution on websites. A website is better than the message, but it is not perfect: criminals can create lookalike sites. The strongest numbers are the ones you held before the request. If you must use a website, cross-check against something else, such as an earlier invoice, a contract, or a record of an earlier call.

Untrusted sources:

- any phone number, email address or link inside the suspicious message
- a reply to the suspicious email
- a new number "to reach me directly"
- a messaging-app contact sent by the same person

- a number found by clicking an advert or search result without cross-checking

The NCSC gives the same general advice: if you are unsure of a message, contact the organisation yourself using details from its official website or other trusted source, not the phone number, link or contact details in the message.[3] Its phishing guidance likewise recommends checking important email requests by another method, such as a phone call, text, logging in to an account, or written or in-person confirmation.[5]

What to ask, and what not to ask

A weak check can look like a strong one. Compare:

Weak verification	Stronger verification
"Are your new bank details XX-XX-XX?" (reading out the fraudster's details for a yes)	"Please tell me the account details you'd like us to use." (the supplier states them; you compare)
Calling the number in the email	Calling a number from your records
Emailing "can you confirm?" and getting "yes" in reply	Speaking to a named person, noting who and when
Asking someone who first told you about the change	Asking an authorised contact other than the sender, where possible
Accepting "the director says it is fine"	Hearing it from the person yourself

A good rule: let the supplier **say** the details; don't let them just **agree** to yours.

S: Secure approval

Obtain the required independent authorisation under the company's payment policy.

Verification tells you the instruction is genuine. Approval makes sure no single person's judgement, mistake or manipulation can release the money.

- The person who **checked** should not be the only person who **approves**.
- The approver should see the **evidence**, not just a request to "approve this".
- Approval should be recorded in a system, not a chat message that can be edited or forged.
- Urgency does not change who must approve.

Chapter 6 shows how to do this with two people, with one person, and with an outsider such as your accountant.

E: Evidence

Record what was checked, who verified it, who approved payment, and when.

Evidence is not bureaucracy. It does three useful things:

1. **It makes you do the check.** Writing "called Mark at Calder on 01632 960 123" is harder to fake than remembering you did.
2. **It supports a prompt response.** If something goes wrong, you know exactly what was verified, which helps your bank, the police, your insurer and your adviser.
3. **It shows your business acted responsibly**, which may matter to partners, regulators or insurers.

A good record takes under two minutes: date and time, who you spoke to, what number you used and where it came from, what was confirmed, who approved.

Good and bad practice side by side

> **Fictional.** Two offices receive the same email: "Our bank details have changed. Please pay today."

	Office A (poor)	Office B (PAUSE)
First reaction	"Better do it before they chase."	"Bank change. Pause."
Check	Replies to the email: "Please confirm"	Calls the number in the supplier file
Answer	"Yes, confirmed." (from the fraudster)	Supplier: "We haven't changed anything."
Approval	Owner pays from the phone	Change rejected; owner informed
Record	None	Incident note and a warning to the supplier
Outcome	Funds lost	Fraud attempt stopped

Proportionality

PAUSE is a mindset, not a bureaucratic burden. For a routine £40 invoice at the usual account, "Assess" takes seconds. For a new bank account on a £48,000 invoice, all five steps matter and deserve real time. **Scale the effort to the amount and the risk.**

The PAUSE checklist

Print this and keep it at the payment desk. A copy with signature lines is in Appendix B.

- ☐ **P**ause: did anything feel new, changed, urgent, secret or unusual?
- ☐ **A**ssess: PO or contract found; amount and bank details compared to our records
- ☐ **U**se an independent channel: called a number **we already held**; spoke to a named person
- ☐ **S**ecure approval: second person reviewed the evidence and approved under policy
- ☐ **E**vidence: date, time, name, number used, outcome and approver recorded

> **The rule:** Never verify using the contact details supplied with the instruction you are checking.

CHAPTER 5

The Supplier Bank-Detail Change Procedure

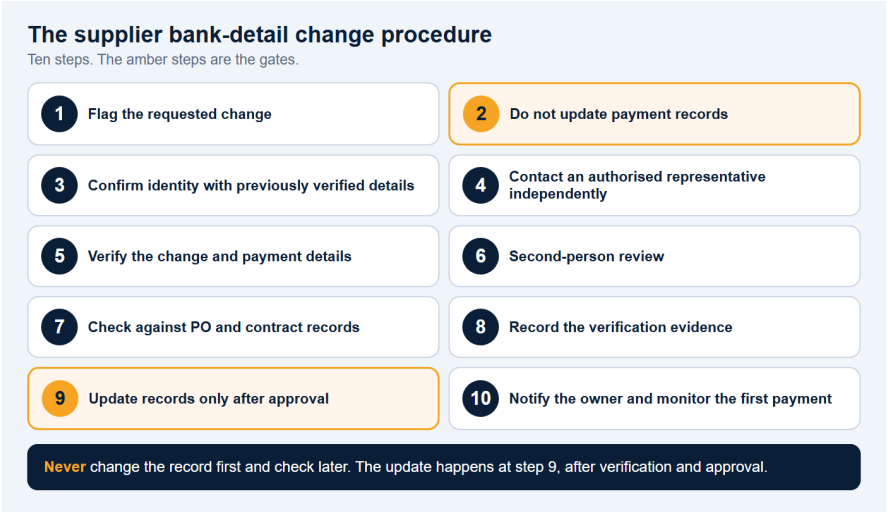


If you adopt only one process from this book, make it this one.

A supplier's bank details are the single most valuable thing a payment fraudster can change. The change is small, the effect is permanent (every future payment goes to the criminal until someone notices), and the request often looks routine. Take Five to Stop Fraud, the UK banking and policing campaign, advises businesses to question any change to payment details, noting that companies rarely change bank accounts, and to confirm bank details directly with the supplier before paying.[6]

That is why **a change to supplier bank details should always trigger its own verification process**, even when the request seems to come from a familiar contact, in a familiar thread, from a familiar address.

> **Prominent instruction.** Do not update supplier payment records until the required verification and approval steps are complete. A bank-detail change request is not a payment instruction. It is a request to be investigated.



The ten-step bank-detail change procedure

The ten steps

Step 1. Flag the requested change

The moment anyone sees a message that mentions "new bank details", "updated account", "we have moved bank" or a different account on an invoice, they label it and pass it to the person who owns the procedure. Don't reply to the sender. Don't forward it to the whole office.

Why: A flagged change cannot be handled casually. Everyone in the business who touches invoices must know this phrase triggers the procedure.

Step 2. Do not update payment records immediately

Leave the existing details in place. If a payment is due, **pay nothing to the new account**. If the supplier's existing account is still valid and the payment is genuinely due, it may be possible to pay it to the old details once the supplier confirms that route is still open. If in doubt, pause the payment.

Why: Most losses happen because a record is changed first and checked later, or never.

Step 3. Confirm the supplier's identity using previously verified contact details

Open your own supplier file. Find the contact information that you held *before* the request: a phone number from the contract, an earlier verified call, or a number you recorded when you onboarded the supplier.

Why: The only contact details you can trust are ones the fraudster could not have inserted into this request. If you have none, treat the supplier as if you were onboarding them for the first time (see Chapter 6) and establish a trusted route before anything else.

Step 4. Contact an authorised supplier representative independently

Phone the supplier. Ask for a person who is authorised to deal with bank details, typically a credit controller, finance manager or director, not just the person who sent the email. **Do not reveal the new details first.** Say that you have received a message about a change and that you would like to confirm it.

Why: The person who sent the request may be a fraudster, or may be a genuine employee whose mailbox has been compromised. An independent contact tells you which.

Step 5. Verify the requested change and the payment details

Ask the supplier to **state** what they are asking you to do, including why the account is changing, the account name, and the payment reference. Compare it against the request. Pay attention to whether the account name matches the supplier's legal name, and whether the account is held in a country you would expect.

A **name check** offered by your bank can help, but treat it as a signal and not a guarantee. In the UK, many banks offer a service that compares the payee name to the account holder name; similar checks are being introduced for euro payments in the EU. A match tells you the name resembles the account's holder. It does not tell you that the account belongs to the supplier you meant, or that a criminal is not operating an account in a similar name.

Why: A single check, such as confirming a company name or an account number, is not always enough. Verification should reflect the amount, the risk, the payment controls available to you and any procedures your bank requires.

Step 6. Use an approved second-person review

A second person, who did not receive the request and does not benefit from the speed of the payment, reviews the evidence and signs off. If you are a one-person business, use the alternatives in Chapter 6.

Why: A second pair of eyes catches mistakes and resists pressure. It also protects the first person from being the sole decision-maker under duress.

Step 7. Check consistency with purchase orders and contract records

Compare the request with what you know. Is there an open order? Does the contract say anything about payment details or notice of change? Are there recent invoices that used a different account? Is the supplier's country of account consistent with theirs?

Why: Genuine changes usually fit the paper trail. Unexplained ones often do not.

Step 8. Record the verification evidence

Complete the Supplier Bank-Detail Change Checklist (Appendix A). Save the original message, a note of who you spoke to, the number used, the time and the outcome. Store it where your accountant or an auditor could find it.

Why: A written record prevents shortcuts, and makes any later problem easier to investigate.

Step 9. Update supplier records only after approval

Only the designated person updates the supplier master data, and only after the approver has signed the checklist. Keep the old details on file, marked as superseded, for traceability.

Why: The update is the moment the risk becomes real. Gate it.

Step 10. Notify the internal owner and monitor the first payment

Tell the person responsible for the supplier relationship. For the first payment to the new account, consider a smaller **test payment** first for larger amounts, and ask the supplier to confirm receipt through the trusted route. Take Five suggests this approach for first-time payees.[6] Then monitor for any complaint of non-payment.

Why: If something slipped through, you want to find out after one payment, not twelve.

Why a familiar sender or thread is not enough

Fraudsters often work from a **genuine** account. If a supplier's mailbox has been compromised, the request can come from their real address, in their real thread, at a plausible moment, with their usual sign-off. Nothing about the message will look wrong, because nothing about its *origin* is wrong. The attacker simply has the keys.

Which means: **the thread is not a security control.** Only the call-back is.

How the procedure handles three situations

> **Fictional.** All three scenarios below are invented for teaching.

Scenario A. A legitimate bank-detail change

Harbourside Joinery has supplied Fenwick Design for six years. In March, Fenwick's accounts assistant, Tomasz, receives a letter and an email from Harbourside announcing a bank change after a merger of two branches.

1. **Flag.** Tomasz marks the request and tells his manager, Ayesha.
2. **No update.** The record is untouched.
3. **Identity.** Tomasz opens Harbourside's supplier file and finds the finance office number he recorded two years earlier.
4. **Independent contact.** He phones and asks for the credit controller, Mr Okafor.
5. **Verify.** Mr Okafor explains the change, states the new sort code and account number, and confirms the account name. They match the letter.
6. **Second review.** Ayesha checks the evidence and agrees.
7. **Consistency.** There is an open purchase order and the letter is on Harbourside's headed paper, which matches a previous letter on file.
8. **Record.** The checklist is completed and saved.
9. **Update.** Ayesha updates the master data. The old details are archived.
0. **Monitor.** The first payment is made. Mr Okafor confirms receipt the next day.

Outcome: The change took 25 minutes and cost nothing. The procedure did not obstruct a genuine request. It documented it.

Scenario B. A fraudulent change from a lookalike address

Back at Bramwell Print Studio (Chapter 1), suppose the procedure is in place.

1. **Flag.** Priya recognises "changed bank" and flags it.
2. **No update.** Marcus is told the payment will wait for verification.
3. **Identity.** Priya looks in the supplier file: a number for Calder's credit control, recorded at onboarding.
4. **Independent contact.** She phones and asks for the accounts team.
5. **Verify.** The accounts team say they have not changed banks and haven't sent such a request.
6. **Outcome.** The change is rejected. The real Calder asks for the email to be forwarded to them.

7. **Follow-up.** Priya notes the lookalike address, files an incident note (Appendix E), and reports through the proper route (Chapter 8).

Outcome: The payment never went out. The address's missing letter was never even noticed. The call-back did the work.

Scenario C. A fraudulent change from a compromised supplier account

Redfern Logistics is a long-standing freight partner of Quill & Anchor Books. A criminal has taken over a Redfern employee's mailbox. A message arrives from the real address, in the live thread about a real shipment, asking Quill & Anchor to use a "new settlement account".

1. **Flag.** The finance manager, Jo, flags it. The address looks perfect, which she notes is not reassuring.
2. **No update.** Nothing changes.
3. **Identity.** Jo uses the number on the signed contract, not any number in the email.
4. **Independent contact.** She asks to speak to someone in Redfern's finance team *other than* the sender.
5. **Verify.** The finance manager at Redfern says nobody has requested a change.
6. **Outcome.** Jo rejects the change and tells Redfern that their mailbox may have been compromised, so they can secure it and alert their other customers.

Outcome: The scam was caught because verification did not depend on the email's appearance. Jo also did the supplier a favour.

When the procedure meets resistance

Expect pushback. Common lines and sensible responses:

What you hear	What to say
"It's urgent, please just pay."	"I understand. As soon as we've verified it, we'll pay. It's our standard process for any bank change."
"Our phones are down. Please use email."	"We'll wait until we can speak. Could you let us know when the line is back?"
"We've always done it this way."	"That's exactly why we check. Fraudsters rely on familiarity."
"Don't tell anyone about this."	"We can't do that. We share bank changes with a second person under policy."

A genuine supplier will understand. A fraudster will push. **Pushing is information.**

The rule: A bank-detail change is a request, not a payment instruction. Do not update records or pay until it has been verified independently and approved.

CHAPTER 6

Build a Payment Process That Is Difficult to Manipulate



Procedures only help if the business is arranged to follow them. This chapter turns the habits of Chapters 4 and 5 into everyday controls. All are suitable for small teams. None needs special software.

The thinking behind it

A control is just a point where the fraud has to get past a person, a rule or a record. The more independent the control, the harder it is to defeat. A strong small-business process rests on three ideas:

1. **No one person can create, change and release a payment alone** (where possible).
2. **Changes are treated differently from routine payments.**
3. **Everything leaves a trail.**

The thirteen controls

1. Separate preparation from approval

The person who enters or prepares the payment is not the person who approves it. This single rule defeats a large share of impersonation scams, because the fraudster has to fool two people.

2. Two-person authorisation where proportionate

Use dual approval for larger or riskier payments (see the matrix below). Many business bank accounts allow you to require two approvers for payments above a threshold. Check what your bank offers and set it up.

3. Approval limits tied to value and risk

Set limits by amount *and* by risk category. A £500 payment to a new payee in a new country is riskier than a £2,000 payment to a supplier you have used for years.

4. Supplier onboarding checks

Before adding a new supplier, confirm that they exist and that you have trusted contact details:

- a signed quote, contract or order form
- a registered company name and number (for UK companies, check the public register; for others, the relevant national register)
- a named contact and a **verified phone number** that you obtained from an independent source
- bank details provided on headed paper **and confirmed by a call**
- a second person's approval

5. Purchase orders and invoice matching

Where practical, match each invoice to a purchase order and a record of delivery. A simple "three-way match" (order, delivery, invoice) is the quickest way to expose a fake invoice from a fictitious vendor.

6. Duplicate-invoice detection

Keep a register of paid invoices (a spreadsheet is fine) with supplier, invoice number, date, amount and payment date. Search it before paying. Look out for invoices with similar numbers, repeated amounts, or "reminders" for invoices already settled.

7. New-payee verification

A first-time payee should always be verified (Chapter 5 procedure), and large first payments considered for a small test payment first.[6]

8. Independent confirmation of unusual requests

Define what "unusual" means in your business: a new method, a new country, an out-of-hours request, an amount well above the norm. Anything meeting the definition requires a call-back.

9. Controlled access to banking platforms

- Give each person their own login. **Never share credentials.**
- Give each person only the permissions they need (view, prepare, approve).
- Use multi-factor authentication on banking and email accounts.

- Remove access promptly when someone leaves or changes role.

The NCSC's small-organisation guidance covers securing your important online accounts and is a good companion to this chapter.[3]

10. Restrict changes to supplier master data

Only named people may change supplier bank details, and every change requires a checklist. If anyone can edit the supplier list, anyone can be tricked into editing it.

11. Documentation and audit trails

Keep the evidence (Appendix A, B and E) for as long as your accountant advises. Prefer systems that record who did what and when.

12. Temporary exceptions and their approval

Sometimes the owner is away or a deadline is real. Allow exceptions, but make them **rare, written and approved**. An exception log (date, reason, approver, outcome) keeps flexibility from becoming a loophole.

13. Regular review of payment permissions

Every quarter, review who has access to what. People accumulate permissions. Remove what's not needed.



Controls scaled to value and risk

A sample payment approval matrix

> **Examples only.** The figures below are illustrations. Choose thresholds that suit your turnover, risk appetite, banking limits and insurance conditions. They are **not** recommended or required amounts.

Payment type	Value or risk (example)	Preparer	Verifier	Approver	Additional controls
Routine payment to established supplier, unchanged details	Under £2,500 (example)	Finance assistant	Not required	Finance lead	Duplicate check
Routine payment to established supplier, unchanged details	£2,500 to £25,000 (example)	Finance assistant	Finance lead	Owner or director	PO or delivery match
Any payment above upper threshold	Over £25,000 (example)	Finance lead	Second director	Owner and one other	Call-back on the first payment of the year
Change of supplier bank details	**Any value**	Finance assistant	Finance lead (call-back)	Owner or director	Appendix A; first payment reviewed
New payee	Any value	Finance assistant	Finance lead (call-back)	Owner or director	Onboarding checks; test payment considered
Payment outside the UK or outside the normal currency	Any value	Finance lead	Owner	Second director	Reason documented
Urgent or exceptional request	Any value	Finance lead	Owner (call-back)	Second director	Exception log
Payroll or HMRC/tax payments	Fixed schedule	Finance assistant	Finance lead	Owner	Amounts reconciled to the schedule

Appendix D contains a blank, editable version.

If one person handles all payments

Many small businesses have a single person, often the owner or a part-time bookkeeper, who receives invoices, updates records and sends payments. Perfect separation is not possible. Replace it with the next best thing: **make someone else look.**

Situation	Proportionate alternative
Owner does everything	Ask your accountant or a trusted adviser to review every bank-detail change and every payment above a threshold you set.
Bookkeeper is external	Require that the bookkeeper may *prepare* payments but only you may *release* them, and that you hold the call-back step.
No one else available	Use a **cooling-off rule**: any change or unusual request waits 24 hours before action, and is re-read the next day.
Banking app allows only one approver	Add a monthly review: someone else reads the bank statement and a list of new payees.
Home-based sole trader	Write your verification rules on a card by the desk and follow it every time, especially when you are rushed.

The principle is the same: **a second look, or a delay, or both.**

Make it easy to do the right thing

Controls that are slow and awkward get bypassed. Keep these simple:

- one shared checklist, not three
- a named person for each step
- a standing script for supplier calls (Appendix F)
- a way for any employee to say "this needs verification" without feeling they are accusing someone

And one cultural rule matters more than any technical one: **anyone may pause a payment, and nobody is criticised for doing so, including when it turns out to be genuine.**

> **The rule:** Design the process so that no single person, message or moment of pressure can move money.

CHAPTER 7

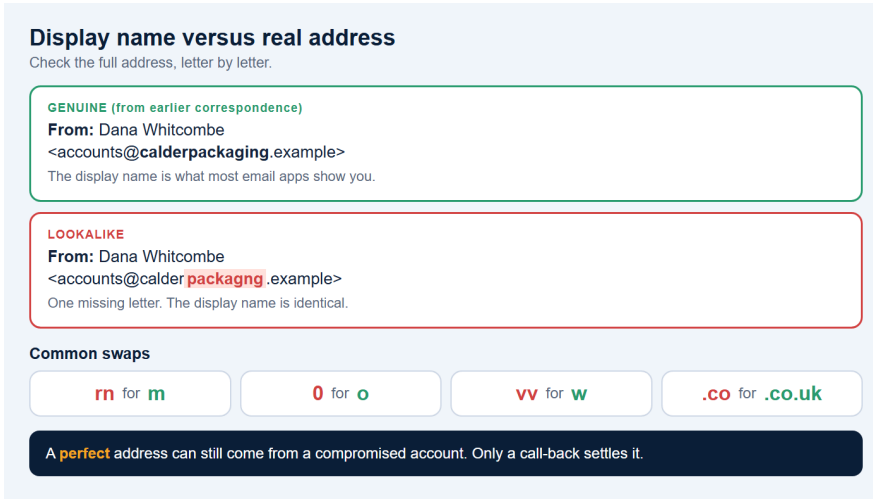
Warning Signs That Deserve a Second Look



This chapter is a field guide. Each warning sign has four short answers: **why it matters**, **what to check**, **what not to do**, and **when to escalate**.

Two caveats apply to all of them.

- **Warning signs are indicators, not proof.** Genuine suppliers sometimes change banks, work to tight deadlines and send odd emails. A warning sign means *look again*, not *accuse*.
- **The absence of warning signs does not mean a request is genuine.** A well-run fraud may show none. That is why the controls in Chapters 5 and 6 do not depend on spotting signs.



Display name versus real address

1. Unexpected bank-detail changes

- **Why it matters:** Changing the destination account is the objective of payment diversion fraud. Companies rarely change banks, so a change is rare enough to merit a check.[6]
- **Check:** Run the Chapter 5 procedure. Compare against the details already held and earlier invoices.
- **Don't:** Update the record, reply with questions, or pay "just this once" to the new account.
- **Escalate when:** the supplier cannot be reached by trusted means, or says they did not send it.

2. Urgent payment deadlines

- **Why it matters:** Pressure shortens the time you have to think. The NCSC lists urgency among the common signs of phishing.[3]
- **Check:** Is the deadline in the contract? What actually happens if payment is a day late? Ask the supplier to confirm the deadline by phone.
- **Don't:** Skip approvals or verification to meet a deadline.
- **Escalate when:** urgency is combined with a change, secrecy or a new payee.

3. Requests to keep a transaction confidential

- **Why it matters:** Secrecy prevents the second pair of eyes that would catch the fraud.
- **Check:** Is there a legitimate reason, such as a confidential acquisition? Even then, the people who approve payments must know.
- **Don't:** Agree to hide it from your manager, accountant or colleagues.
- **Escalate when:** anyone asks you to conceal a payment from the people who would normally approve it. Escalate immediately.

4. Changes in tone or communication style

- **Why it matters:** A different voice may mean a different writer. But tone can be imitated (Chapter 3), so a *consistent* tone proves nothing.
- **Check:** Does the message follow the person's normal pattern: greeting, sign-off, time of day, signature, way of asking?
- **Don't:** Rely on "it sounds like them" as your check.
- **Escalate when:** a change in tone comes with any instruction involving money.

5. Unusual sender addresses

- **Why it matters:** Lookalike domains (a missing letter, a swapped character, a different ending such as `.co` for `.co.uk`) are a common trick. The display name can say anything; the real address sits behind it.
- **Check:** Expand the full address. Compare it letter by letter with a previous genuine message. Look for a different "reply-to" address.
- **Don't:** Rely on the display name or the logo. And don't conclude that a *correct* address is safe: it may come from a compromised account.
- **Escalate when:** the address differs from earlier correspondence, or the reply-to differs from the sender.

6. New or unfamiliar beneficiaries

- **Why it matters:** A new payee is the point where a criminal's account enters your system.
- **Check:** Is the payee in your supplier records? Does the account name match the supplier's legal name? Does a purchase order exist?
- **Don't:** Add a payee because a message says so.
- **Escalate when:** the beneficiary differs from the supplier named on the invoice, such as a personal name, a different company, or a third party "collecting on our behalf".

7. Inconsistent invoice references

- **Why it matters:** Fraudulent documents often copy a real invoice but get references, dates or sequences slightly wrong.
- **Check:** Compare with the previous invoice: numbering sequence, format, VAT number, payment terms, address, remittance advice.
- **Don't:** Assume a mistake is innocent, or fix the error yourself and pay.
- **Escalate when:** inconsistencies appear alongside a bank change.

8. Mismatched purchase orders

- **Why it matters:** A fake or inflated invoice often has no matching order.
- **Check:** Is there a PO? Do quantity, price and description agree? Was delivery received?
- **Don't:** Pay an invoice because it looks like one you would normally pay.
- **Escalate when:** the person named as the orderer does not recall ordering it.

9. Unusual payment amounts

- **Why it matters:** Criminals often choose amounts just under an approval limit or well above the usual, depending on what they think you will accept.
- **Check:** Compare against typical invoices from that supplier. Does the total match the quote?
- **Don't:** Split a payment to fit a limit, or accept a request to do so.
- **Escalate when:** an amount is unusually large, round or just below a threshold.

10. Unexpected international transfers

- **Why it matters:** International payments can be harder to trace or recall, and an unexpected foreign account for a domestic supplier is a strong signal.
- **Check:** Is the country of the account consistent with the supplier's location? Is the currency expected?
- **Don't:** Send international payments on the strength of an email.
- **Escalate when:** a domestic supplier asks for an overseas account, or the destination country is new.

11. Requests to bypass normal approvals

- **Why it matters:** This is the clearest behavioural signal: the instruction is designed to avoid your controls.
- **Check:** Who is asking, and do they have the authority to waive the process? (Usually nobody does, because the process protects the business.)
- **Don't:** Comply, even if the request comes from the owner by email. Use the call-back.
- **Escalate when:** the request is made by someone senior; escalate to a second director, owner or accountant.

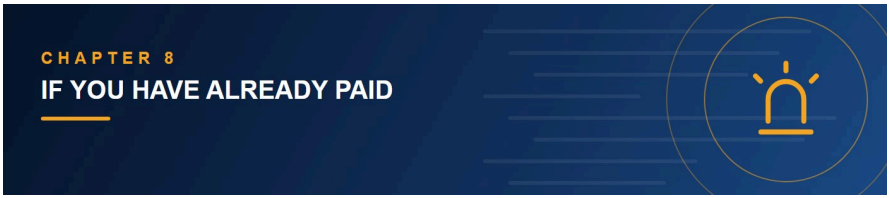
12. Messages that discourage telephone verification

- **Why it matters:** The fraudster cannot afford a conversation. "Email me, I'm travelling" is a way to avoid being asked a question.
- **Check:** Can someone else at the supplier, whose number you hold, confirm the request?
- **Don't:** Accept "calls aren't possible" as a reason to skip verification.
- **Escalate when:** the person refuses all alternative verification routes.

The rule: One sign calls for a second look. A combination of signs calls for a firm stop until you have verified.

CHAPTER 8

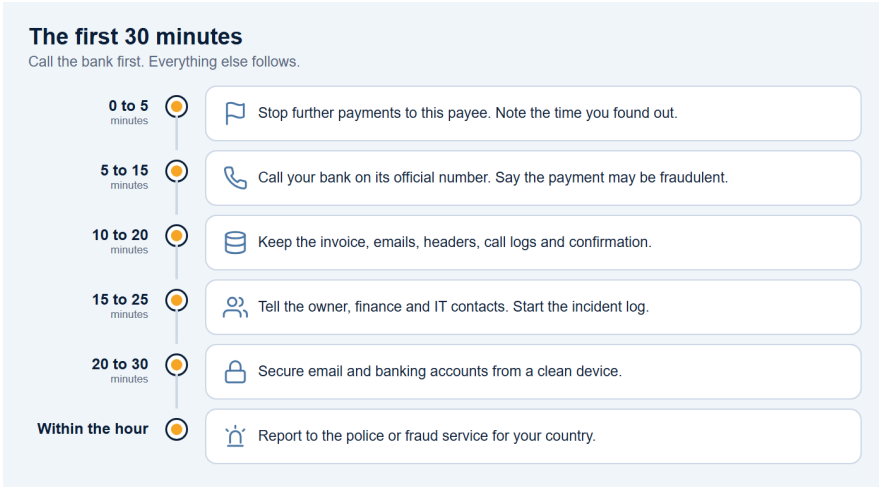
What to Do If You Have Already Paid



Suppose it has happened. You realise a payment went to the wrong account, or you have a bad feeling about one that has just left. Stay calm. What you do in the next hour matters more than anything you could have done last week.

This chapter is a procedure to follow, not a lecture. Print it. Share it. Practise it.

> **Honest expectations.** Prompt reporting may improve the opportunity for a bank to intervene, but recovery depends on the circumstances and the institutions involved. Nobody can promise that money will come back. Do not delay contacting your bank while you investigate internally. In the UK, reimbursement rules for authorised push payment fraud cover some small businesses but not all, and do not apply to every payment. Ask your bank whether your business is eligible, and do not assume it is.[11]



The first 30 minutes

The nine steps

1. Contact the sending bank or payment provider immediately

Use the **official phone number or website** of your bank, taken from your own records, your card or the bank's genuine site. Do not use contact details from the suspicious message.

The NCSC's guidance for business payment fraud says the same thing: if a fraudulent payment has been made, stay calm, act quickly, tell your IT contact so they can help, and contact your bank using the phone number or website from its official channels.[1]

2. Explain that the payment may be fraudulent

Say clearly, "I believe we have made a payment as a result of fraud." Give the date, time, amount, payment method (for example, Faster Payments, CHAPS, SEPA, card, international transfer) and the account details used. Ask what urgent options exist: recall, tracing, contacting the receiving bank, freezing, or other steps. The options differ by payment type and country, and the bank will know which apply.

3. Preserve the evidence

Do not delete anything. Keep:

- the invoice and any attachments (in their original form, not just a printout)
- the email chain, ideally with full headers (ask your IT contact or email provider how to export them)
- the bank details used and the payment confirmation
- call records, voicemails and messaging-app chats
- screenshots with times and dates

4. Notify the business owner and the right internal contacts

Tell the owner, the finance lead and whoever looks after IT or your email system. Keep it factual and keep the circle of people small until you know what you are dealing with.

5. Follow the local police or fraud-reporting procedure

The right route depends on where you are:

- **England, Wales and Northern Ireland:** the national service is **Report Fraud**, run by the City of London Police, which has replaced Action Fraud (reportfraud.police.uk; 0300 123 2040 at the time of writing).[7]
- **Scotland:** report to Police Scotland, using 101.[7]

- **Elsewhere in Europe:** your national police or fraud-reporting authority. Your bank can tell you the right route, and many countries have an online reporting portal.
- **UK organisations that have had a cyber incident** can also report through the NCSC's reporting service at gov.uk/report-cyber.[1]

Verify these details on the official sites before you rely on them. They change.

6. Assess whether personal data or confidential information was exposed

Did the fraud involve a compromised mailbox? Did the criminal see customer lists, staff details or bank records? Chapter 9 explains how to decide whether this is also a data-protection incident.

7. If an account may be compromised, secure it

Change the passwords of affected email and banking accounts from a **clean device**, turn on multi-factor authentication, check for forwarding rules the attacker may have added, sign out other sessions, and follow your incident-response process. The NCSC has a step-by-step guide for recovering hacked online accounts.[1]

8. Document actions and decisions

Start the Incident Log (Appendix E) at once. Record times, names, reference numbers and what you were told.

9. Review the failed control and introduce corrective measures

Once the urgent work is done, ask a plain question: *which control would have stopped this, and why was it missing or bypassed?* Fix the process, not the person. Review in a blame-free way so that the next person speaks up faster.

What not to do

- **Don't wait for an internal investigation** before calling your bank.
- **Don't reply** to the fraudster, challenge them or confront them.
- **Don't send further payments** to "fix" the problem.
- **Don't pay "recovery agents"** who approach you after a fraud. Recovery scams are real; be suspicious of anyone who contacts you offering to get money back for a fee.
- **Don't assume the money is gone.** Act as if there is a chance.
- **Don't blame the employee involved.** Someone who fears punishment will hide the next incident.

The "First 30 Minutes" emergency checklist

Print this page and keep it near your banking login.

- ☐ **Minutes 0 to 5.** Stop any further payments to this payee. Write down the exact time you discovered it.
- ☐ **Minutes 5 to 15.** Call your bank on its **official** number. Say: "I believe we have made a fraudulent payment." Give date, amount, account details. Ask what urgent action is possible. Note the name of the person and any reference number.
- ☐ **Minutes 10 to 20.** Preserve the invoice, emails, headers, call logs and confirmation. Do not delete or forward them widely.
- ☐ **Minutes 15 to 25.** Tell the owner and your finance and IT contacts. Ask someone to start the incident log.
- ☐ **Minutes 20 to 30.** Secure any email or banking account that may be compromised (from a clean device).
- ☐ **Within the hour.** Report to the police or fraud-reporting service for your country. Tell your insurer if you hold cover (check the policy's notice requirements).
- ☐ **Same day.** Note whether any personal data may be involved, and ask for qualified advice if you are unsure (Chapter 9).

A simple incident log

A fuller template is in Appendix E. At minimum record:

Time	Who	What was done or said	Reference

> **The rule:** If money may have left the account, call the bank first. Everything else comes second.

CHAPTER 9

When Customer or Employee Data Is Also Exposed



Most invoice scams are about money. Some are also about information. This chapter explains how the two can overlap, and gives you a calm way to ask the right questions.

> **Not legal advice.** Data-protection law differs by country and depends on the facts. This chapter explains the general framework. Where the facts or your obligations are uncertain, obtain qualified guidance promptly. Do not let uncertainty delay your bank call (Chapter 8).

When an invoice scam touches personal data

Personal data means any information relating to an identified or identifiable living person: names, email addresses, phone numbers, bank details of a sole trader, staff records, customer lists. Invoices and supplier records often contain more of it than people realise.

Situations where the two problems meet:

- **Personal data in invoices and supplier files.** Names, addresses, and bank details of sole traders and freelancers.
- **A compromised email account** that holds customer correspondence, attachments or contracts.
- **Exposure of employee or supplier bank details**, for example payroll or contractor files.
- **Unauthorised access to an accounting platform** that holds customer and supplier records.
- **A fraudster's use of your records** to make a convincing approach to your customers or suppliers.

Not every invoice scam is a personal-data breach

This is the key point. Compare:

Situation	Is personal data compromised?
You pay a fake invoice that arrived by email. Nothing else was accessed.	Usually no. It is a fraud, not necessarily a personal-data breach.
A fake invoice arrives because a criminal read your supplier's mailbox.	Possibly yes for the supplier's mailbox; their obligations are theirs.
A criminal accessed *your* mailbox and could read customer data.	Possibly yes. Assess it.
An employee sent a spreadsheet of staff bank details to a fraudster posing as an auditor.	Yes, probably.

Each case turns on the facts. The same event can be a fraud, a security incident, and a personal-data breach all at once, or only the first.

The GDPR framework, in plain terms

The EU General Data Protection Regulation (GDPR) and the UK GDPR (the UK's retained version) use a very similar structure for personal-data breaches. Check the rules that apply to your business and your country.

What counts as a breach. A personal-data breach is a security incident leading to the accidental or unlawful destruction, loss, alteration, unauthorised disclosure of, or access to, personal data. The ICO describes it as a security incident affecting the confidentiality, integrity or availability of personal data, and notes that it can be accidental or deliberate.[8]

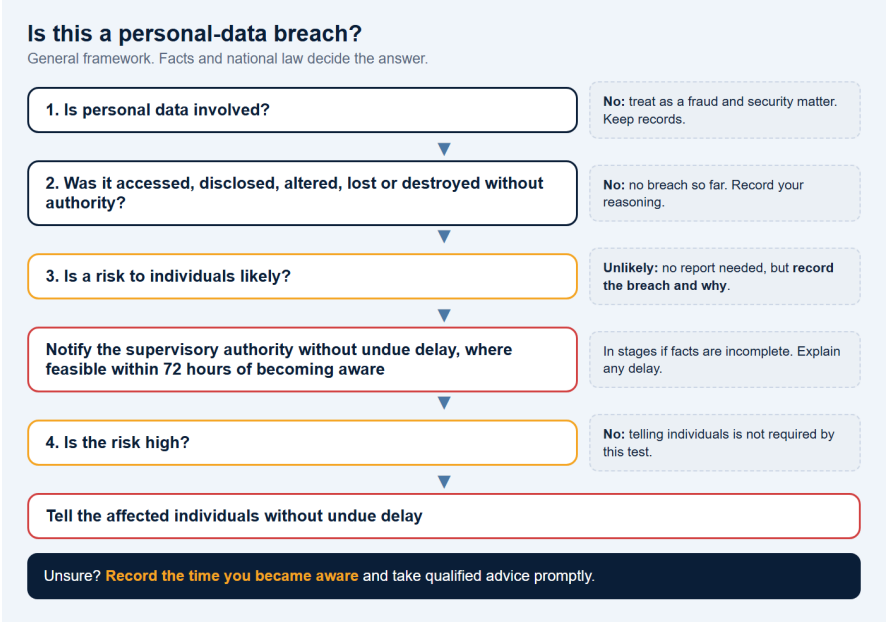
Telling the regulator. If a breach is **likely to result in a risk to people's rights and freedoms**, the organisation responsible for the data (the *controller*) must notify the supervisory authority **without undue delay and, where feasible, within 72 hours of becoming aware of it**. If the risk is unlikely, notification is not required, but the breach must still be **recorded**, with the reasoning.[8][10]

Telling individuals. If the breach is likely to result in a **high** risk to individuals, they must be told directly and without undue delay. The threshold for telling individuals is higher than for telling the regulator.[8][10]

Late notification. If notice is given after 72 hours, the reasons for the delay must be given. Information may be provided in phases when not everything is known yet.[8]

Who notifies. A *processor*, an organisation handling data for you, must tell you without undue delay if it becomes aware of a breach. You, as controller, then have the regulatory duty.[10]

Which authority. In the UK, the Information Commissioner's Office (ICO). In the EU, the national supervisory authority of the relevant member state; the European Data Protection Board publishes the list.[9]



Is this a personal-data breach?

"Awareness" versus "suspicion"

The 72 hours run from when you **become aware** of a breach, not from when it happened, and not from the moment you first suspected a payment scam.

The European Data Protection Board's guidelines on breach notification treat a controller as aware when it has a reasonable degree of certainty that a security incident has occurred that has led to personal data being compromised. That is not the same as a first hunch, and the guidelines expect a controller to investigate promptly rather than leave a suspicion unexamined.[9] (Check the exact wording in the current version before you rely on it for a decision.)

For an invoice scam, that means:

- **A suspicious invoice** is a fraud suspicion. Start the Chapter 8 steps.

- **Evidence that someone accessed a mailbox or file containing personal data** is where the data-breach question begins. Start your assessment promptly and log the time you became aware.
- If you are unsure when "awareness" occurred, **record your reasoning** and take advice.

Assessing the risk

Ask these questions and write the answers down:

1. **What data?** Names only, or bank details, identification numbers, health or other sensitive data?
2. **Whose?** Customers, employees, suppliers, sole traders?
3. **How many people?**
4. **Was it accessed, copied, altered or lost?** Is there evidence of what the criminal saw?
5. **How likely is harm?** Could it lead to identity fraud, financial loss, distress or discrimination?
6. **What have we done to contain it?**

The higher the sensitivity and the likelier the harm, the more likely notification is required.

Preserve evidence without spreading sensitive information

- Keep logs, headers and copies in a **restricted folder**, not in an all-staff channel.
- Share on a need-to-know basis.
- Don't forward spreadsheets of personal data to "get a second opinion" unless the recipient is authorised.
- Redact personal data when you discuss the incident more widely.

Who to involve

- The **business owner or director**.
- Whoever is responsible for **data protection** (a DPO if you have one, or a nominated person).
- Your **IT provider** or the person managing your email system.
- Your **accountant or legal adviser**, if the position is unclear.
- Your **insurer**, if you hold cover.

The limits of this chapter

It cannot tell you whether a particular incident must be reported: that depends on facts and law. It gives you a process: *notice, assess, record, escalate, and take qualified advice when in doubt.*

For general privacy and data-protection resources aimed at European small businesses, see the note about GDPRGard.eu at the end of the book.

> **The rule:** A payment scam is not automatically a data breach, and a data breach is not automatically a payment scam. Ask the data question every time, and write down the answer.

CHAPTER 10

The Small Business Anti-Fraud Policy



A short written policy turns good habits into the way the business works. The template below is deliberately concise. Copy it, replace the placeholders in square brackets, and adjust it to your size and risks. Have your accountant or adviser look it over before adopting it.

> **Template notice.** This is a starting point. It is not a legal document and does not guarantee fraud prevention or compliance with any law. Thresholds and roles are examples to adapt.

Policy template

[Business Name] Payment Fraud Prevention Policy Version [1.0] · Effective [date] · Owner [Policy Owner] · Review [quarterly/annually]

1. Purpose and scope

This policy protects [Business Name] from payment fraud, including fake invoices, supplier impersonation, payment diversion, and business email compromise. It applies to everyone who receives invoices, handles supplier records, prepares, verifies or approves payments, or accesses our banking and accounting systems, including contractors and temporary staff.

2. Supplier onboarding

- A new supplier may be added only with a [quote/contract/order form] and approval from [Payment Approver].
- We verify the supplier's existence using [company register / website / known contact].
- We record a **trusted contact** for each supplier: name, role and telephone number, obtained from [an independent source] and confirmed by a call.
- Bank details are confirmed by a call to the trusted contact before first payment.

3. Invoice verification

Before paying, we confirm that:

- the supplier is in our records
- there is a [purchase order / contract / delivery confirmation]
- the amount, dates and invoice number are consistent
- the invoice is not a duplicate
- the bank details match our records

4. Bank-detail change procedure

- Any request to change supplier bank details, however received, is a **change request**, not a payment instruction.
- Supplier records are **not** updated until verification and approval are complete.
- We verify using the Supplier Bank-Detail Change Checklist (Appendix A), including independent contact.
- Only [Supplier Records Owner] may amend supplier bank details.

5. Independent contact verification

- We use only contact details held in our records before the request, or obtained from [an Approved Verification Method].
- We do **not** use telephone numbers, email addresses or links supplied in the request being checked.
- Verification is recorded: who, when, how, outcome.

6. Payment approval roles and limits

- Payment preparation and approval are performed by different people wherever possible.
- Approvals follow the matrix in Appendix D, as set by [Payment Approver] and reviewed [quarterly].
- No one may approve a payment they prepared or requested.

7. Urgent and unusual requests

- Urgency never waives a check.
- Requests that are **new, changed, urgent, secret or unusual** require independent confirmation before payment.
- Requests from senior colleagues to bypass the process are verified by a second director/owner.
- Any exception is approved by [Exception Approver] and logged.

8. New-payee checks

- A new payee requires onboarding checks, a call-back, and approval by [Payment Approver].
- For first payments above [£X, example], consider a small test payment.

9. Recordkeeping

- Evidence of verification and approval is kept for [period, as advised by our accountant].
- Supplier-record changes are logged with date and name.
- Paid invoices are recorded in the payment register.

10. Incident escalation

- Anyone who suspects a fraudulent payment tells [Incident Lead] immediately.
- If money may have left the account, **the bank is contacted first**, using official contact details, followed by the steps in our Response Flow.
- Incidents are logged (Appendix E) and reviewed.
- Possible personal-data exposure is escalated to [Data Protection Contact] without delay.

11. Staff training

- All relevant staff are trained at onboarding and at least [annually].
- Training uses fictional examples and practice exercises.
- Staff may pause or query any payment without blame.

12. Periodic review

- This policy, approval limits, and system access are reviewed [quarterly].
- Lessons from incidents and near-misses are added.

Approved by: [Owner/Director] · **Date:** [ ]

Staff announcement (copy and send)

Subject: How we handle changes to supplier bank details

Hi everyone,

Fraudsters sometimes pretend to be suppliers and send convincing emails saying their bank details have changed. To protect the business, we are introducing a simple rule from [date]:

If anyone asks us to change where we pay, we verify it first. We do not update records or pay until a second person has checked.

In practice: don't reply to the message; flag it to [Policy Owner]; we will call the supplier on a number we already hold; and we will record what we found.

This applies to everyone, including me. If you are ever asked to hurry, to keep a payment quiet, or to skip a step, please pause and tell me. **You will never be criticised for double-checking.**

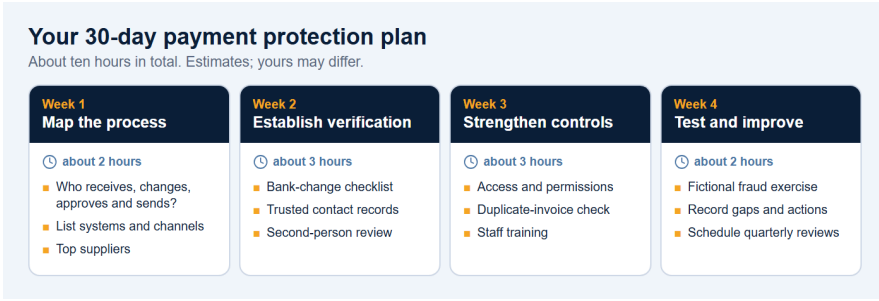
Thank you, [Name]

CHAPTER 11

Your 30-Day Payment Protection Plan



You do not need a month of free time. You need about **ten hours in total**, spread over four weeks, which comes to roughly two to three hours a week (an estimate; your business may need more or less).



The 30-day plan

Week 1: Map the process

Time: about 2 hours **Expected outcome:** you can answer "who can do what with our money?"

Actions

- Identify who **receives** invoices, who **updates** supplier records, who **approves** payments, and who **sends** transfers.
- List the **systems** involved: email, accounting software, banking platform, shared drive, messaging apps.
- List the **communication channels** suppliers use.
- Identify the most common **payment types**: domestic transfers, international, direct debits, cards.
- Note the **top ten suppliers** by value and the top ten by frequency.

Completion checklist

☐ I have a one-page diagram of how an invoice becomes a payment.
☐ I know who has banking access and what level.
☐ I have a list of my top suppliers.
☐ I know which steps depend on a single person.

Week 2: Establish verification

Time: about 3 hours **Expected outcome:** a working bank-detail change procedure and trusted contact records.

Actions

- Copy the **Supplier Bank-Detail Change Checklist** (Appendix A) into your document system.
- Build **trusted contact records** for your top suppliers: name, role, number, source of number, date verified. Obtain numbers from contracts or earlier verified calls, and call to confirm.
- Define **when independent verification is required** (any bank change, any new payee, any unusual request).
- Introduce a **second-person review** where feasible, or one of the alternatives in Chapter 6.

Completion checklist

☐ Checklist saved and shared.
☐ Trusted contacts recorded for the top suppliers.
☐ Written rule on when to verify.
☐ A second reviewer (or alternative) named.

Week 3: Strengthen controls

Time: about 3 hours **Expected outcome:** tighter access, a duplicate-check habit, and a trained team.

Actions

- Review **banking access and approval permissions**; remove what is not needed; switch on multi-factor authentication.
- Set up **duplicate-invoice checks** (a paid register).
- Document **escalation contacts**: bank fraud line (official number), IT contact, accountant, insurer, reporting service.

- **Train staff** using the fictional case studies in Chapter 12 and the scripts in Appendix F.

Completion checklist

- ☐ Access reviewed and cleaned.
- ☐ Paid register in use.
- ☐ Escalation contact sheet saved and printed.
- ☐ Training session held and attendance noted.

Week 4: Test and improve

Time: about 2 hours **Expected outcome:** proof that it works, a list of gaps, and a review date.

Actions

- Run a **fictional invoice-fraud exercise**: send a staff member a made-up bank-change email (clearly agreed in advance with management) and see what happens.
- Test whether staff know **how to verify** a change.
- Confirm that **emergency contact information** is accessible to someone covering your absence.
- **Record gaps** and assign corrective actions with dates.
- **Schedule quarterly reviews.**

Completion checklist

- ☐ Exercise completed and debriefed (blame-free).
- ☐ Gaps listed with owners and dates.
- ☐ Emergency sheet accessible when the owner is away.
- ☐ Next review in the calendar.

Beyond day 30

Treat the plan as the start of a routine. Each quarter:

- check permissions
- re-confirm trusted contacts for key suppliers
- review near-misses and incidents
- refresh training with a new fictional example

The rule: A simple procedure that is actually used beats a sophisticated one that sits in a drawer.

CHAPTER 12

Five Case Files



> **All five cases are fictional.** They are composites written for teaching. They are not real incidents, and no real business, person or loss is portrayed. Names, addresses and figures are invented.

Each file follows the same pattern: what happened, which warning signs were present, which control could have prevented or interrupted it, what the employee should do, and the lesson for the business. Use them for training, as discussion prompts in a team meeting.

Case 1. The lookalike address

The business. Kestrel Garden Centre, 14 staff.

What happened. Amy, in accounts, receives an email from "Orchard Seeds Ltd" saying they have moved to a new bank following a system upgrade. The sender is `accounts@orchardseed5.example`. The genuine domain is `orchardseeds.example`. The invoice attached is for £7,320. Amy updates the supplier record and schedules payment for the next morning.

Warning signs

- bank details changed
- sender domain differs by two characters (`seed5` for `seeds`)
- a reason that sounds administrative ("system upgrade")
- payment requested within a day
- no phone conversation offered

Controls that could have prevented it

- the Chapter 5 procedure: flag, hold, call-back on a recorded number
- restricting supplier master-data changes to a named person
- a second-person review

What the employee should do. Amy should flag the request to her manager, not change the record, and phone Orchard Seeds on the number held in the supplier file. If the supplier says they sent nothing, she records the incident and reports it (Chapter 8).

The lesson. Comparing addresses is good. A call-back is better, because it works even when the address is perfect.

Case 2. The compromised supplier

The business. Linden & Marsh, a 6-person architecture practice.

What happened. Over several weeks, a criminal has quietly read the mailbox of Fieldhouse Surveys, a regular subcontractor, and learns when invoices are due. The week before an invoice is expected, Linden & Marsh gets a message from Fieldhouse's genuine address, in the genuine thread, with the genuine invoice number, asking them to use "our new project account". The invoice is for £12,450. The practice manager, Sunita, notices nothing odd. The email is relaxed and helpful, as usual.

Warning signs

- bank details changed, without prior mention
- the message arrives just before an invoice is expected
- a one-off "project account" with a different account name
- a polite but firm "please don't use the old account"

Controls

- independent verification: a call to Fieldhouse's finance contact using the number on the signed subcontract
- asking for someone *other than* the sender
- a first-payment review

What the employee should do. Sunita should treat it as a bank-detail change however perfect the address looks. If Fieldhouse says they did not send it, she should tell them that their mailbox may be compromised, and keep the message for them and for any report.

The lesson. The sender's address is not evidence of safety. When an account is compromised, everything about the message may be genuine except the account number.

Case 3. The urgent request from the boss

The business. Tidewater Marketing, 11 staff.

What happened. Chloe, the finance assistant, receives a message on a messaging app from a number she doesn't recognise. It says it is the managing director, Rob, using a new phone: "I'm about to go into a client meeting and need a £9,800 payment made to a new supplier today. I'll send the invoice shortly. Please keep this quiet until the deal is announced." A follow-up email arrives from an address that looks like Rob's.

Warning signs

- a new, unrecognised number
- an unusual payment to a new payee
- urgency and secrecy together
- "I can't talk": the sender avoids a call
- an instruction to bypass the usual approvals

Controls

- a written rule that no one, including senior colleagues, may order an unusual payment without a second approver
- a call-back to the director's known mobile
- a new-payee verification

What the employee should do. Chloe should call Rob on the number saved in the company directory, or walk to his desk if he is in. She should tell the other director, and not make the payment until both have confirmed. Because secrecy was requested, she should escalate rather than comply.

The lesson. A rule that applies to the owner as well as everyone else protects staff from being put in an impossible position.

Case 4. The voice message

The business. Ashdown Veterinary Group, 22 staff.

What happened. The practice manager, Femi, receives a voice message on a messaging app. It sounds like the group's founder, Dr Ashdown, who is overseas at a conference. The voice says, "There's been a problem with a laboratory supplier. I need you to wire €18,000 today to the account I'm sending now. I'll explain later." A message follows with account details.

The voice is convincing. The message mentions the conference by name. Femi knows it is a real event.

> **Fictional teaching note.** This case illustrates a possibility described in Chapter 3. It does not describe a documented incident, and we cannot say whether synthetic voice technology would be used in a given attempt.

Warning signs

- an exceptional transfer of a large sum, abroad
- time pressure and "I'll explain later"
- instructions arriving by messaging app, outside the normal approval route
- the sender is out of reach for a proper conversation
- the voice, however familiar, is the only evidence

Controls

- a **call-back** to Dr Ashdown's known number or to another director
- a pre-agreed **verification question or code word** for exceptional requests
- two-person authorisation for all international transfers

What the employee should do. Femi should not act on the message. She should call the founder's usual number, or contact the other director, and use the agreed code if one exists. She should report the attempt internally and keep the voice message.

The lesson. A familiar voice is no longer proof of identity for a request to move money. Plan the check in advance, when nobody is under pressure.

Case 5. The duplicate invoice

The business. Brightwater Events, 8 staff, informal approvals.

What happened. In the busy run-up to a festival, Brightwater pays an invoice for £3,950 from a staging contractor. Three weeks later a message arrives: "Reminder: invoice SC-0412 unpaid. A £250 late fee applies from Friday. Please settle to the account below." The details are different. The owner, Lucas, is travelling. His part-time bookkeeper pays it, as there is no rule about checking the paid register, and approvals are done by messaging "ok".

Warning signs

- a reminder for an invoice that looks familiar
- a late-fee threat and a Friday deadline

- different bank details
- payment approved by an informal message

Controls

- a **paid-invoice register** checked before any payment
- the bank-detail change procedure for any new account
- approvals recorded in the banking platform rather than by chat

What the employee should do. The bookkeeper should search the register, find that SC-0412 was paid, treat the new account as a change request, and ask the contractor to confirm receipt of the original payment via a trusted number.

The lesson. Weak approval habits turn a duplicate into a loss. A five-minute register check would have exposed the reminder.

Using the case files for training

For each case, ask your team:

1. What was the first moment someone could have paused?
2. Which warning signs would we have noticed here?
3. Which of *our* controls would have caught it? Which would not?
4. Who would we have called, and with what number?

Write down the gaps. Fix one per week.

APPENDIX A

Supplier Bank-Detail Change Checklist

> **DO NOT update payment records until every required verification and approval step below is complete.** A request to change bank details is not a payment instruction.

Copy this page into a document or spreadsheet. Complete one per request.

Field	Entry
Supplier name	_____
Supplier reference	_____
Date request received	_____
How it was received (email, letter, call, other)	_____
Requesting contact (name, role, address/number used)	_____
Existing payment details on record	_____
Requested change (new details)	_____
Reason given	_____
Trusted contact method used for verification	_____
Source of that contact detail (contract, earlier call, onboarding record)	_____
Name and role of independently contacted person	_____
Verification date and time	_____
Did the supplier **state** the new details themselves?	Yes / No
Account name matches supplier's legal name?	Yes / No
Purchase order or contract reference	_____
Consistent with orders and contract records?	Yes / No / Notes
Reviewer (second person)	_____
Approver	_____
Evidence location (file path or system)	_____

Decision

- ☐ Approved
- ☐ Rejected

☐ Pending (reason: _____)

Follow-up actions

☐ Supplier records updated by authorised person only, after approval. Date: _____

☐ Old details archived as superseded

☐ Internal owner notified

☐ First payment monitored; supplier confirmed receipt on: _____

☐ If rejected: incident log started (Appendix E); supplier told

Signed (reviewer): _____ Signed (approver): _____ Date: _____

APPENDIX B

Before-You-Pay Checklist

Use before releasing **any** payment. One per payment, or one per batch for routine, unchanged payments.

Supplier identity

- ☐ Supplier is in our records and we know what they supplied
- ☐ Contact details used are from our records, not from the invoice

Invoice legitimacy

- ☐ Invoice number is in sequence and not a duplicate
- ☐ Details (name, address, VAT/tax number) match previous invoices

Amount and due date

- ☐ Amount agrees with quote, contract or purchase order
- ☐ Due date agrees with terms; no unexplained urgency or penalty

Purchase order or delivery

- ☐ PO, contract or delivery confirmation found
- ☐ Goods or services received

Beneficiary and bank details

- ☐ Sort code/account number or IBAN match our records
- ☐ Account name matches the supplier

Unexpected changes

- ☐ No change to bank details, payee, method or contact
- ☐ If any change: Appendix A completed and approved

Approvals

- ☐ Required approvals obtained under the approval matrix (Appendix D)
- ☐ Approver is not the preparer

Independent verification (when indicated)

- ☐ Verified by call to a number we already held
- ☐ Spoke to (name/role): _____

Evidence

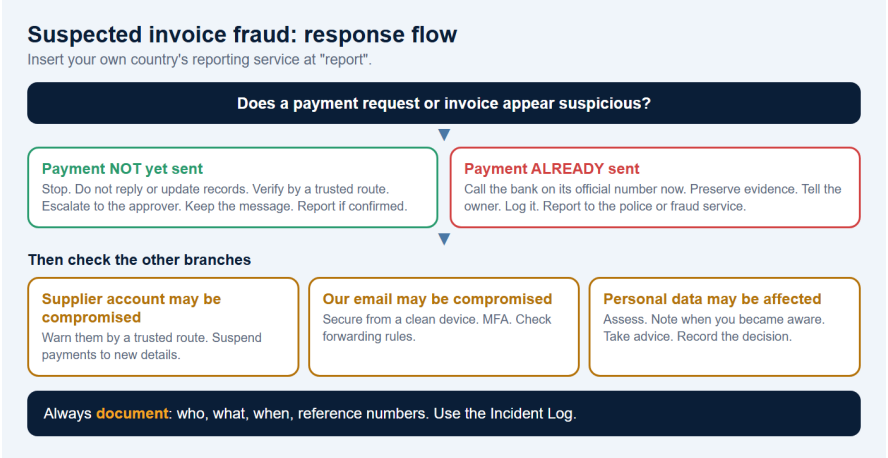
☐ Notes saved at: _____

Prepared by: _____ Approved by: _____ Date/time: _____

APPENDIX C

Suspected Invoice Fraud Response Flow

A text-based decision flow. It does not depend on any one country's reporting service: insert your own at "report".



Suspected invoice fraud response flow

START: Does a payment request or invoice appear suspicious?

If NO: continue the normal process (Appendix B). If anything changes, return here.

If YES, ask: has any money been sent?

Branch 1. Payment NOT yet sent

- *Immediate action:* Stop. Do not reply to the sender. Do not update records or pay.
- *Verify*: Use a trusted, independent contact (Chapter 4, 5). Compare against the records.
- *Escalate*: tell [Payment Approver] and [Incident Lead].
- *Document*: keep the message; complete Appendix A or E.
- *If confirmed fraudulent*: report to the relevant fraud-reporting service for your country; warn the genuine supplier by a trusted route.

Branch 2. Payment ALREADY sent

- *Immediate action:* **call your bank on its official number now.** Tell them the payment may be fraudulent; ask about recall/tracing options.

- *Escalate:* owner, finance lead, IT contact.
- *Document:* start the Incident Log (Appendix E); preserve invoice, emails, headers, payment confirmation, call records.
- *Then:* report to the police/fraud service for your country; tell your insurer if insured; review the failed control.

Branch 3. Supplier's account may be compromised

- *Immediate action:* contact the supplier through a trusted route and tell them; do not use the suspicious email.
- *Escalate:* [Payment Approver]; suspend payments to that supplier's new details.
- *Document:* record who was told, when, and what they said.
- *Then:* resume payments only to previously verified details after the supplier confirms their systems are secure.

Branch 4. Our own email account may be compromised

- *Immediate action:* from a **clean device**, change passwords, enable multi-factor authentication, sign out other sessions, check for forwarding rules.
- *Escalate:* IT contact or provider; owner.
- *Document:* time of discovery, accounts affected, actions taken.
- *Then:* consider whether suppliers or customers have received fraudulent messages from us, and warn them; follow NCSC (UK) or national equivalent guidance; assess data exposure (Branch 5).

Branch 5. Personal data may be affected

- *Immediate action:* contain: secure accounts, limit access, preserve evidence.
- *Escalate:* [Data Protection Contact]; take qualified advice if uncertain.
- *Assess:* is it a personal-data breach; is there a likely risk to individuals; has the 72-hour clock started (when did we become aware?).
- *Document:* the assessment and decision, **whether or not** you notify the regulator.
- *Then:* notify the supervisory authority and individuals where required.

APPENDIX D

Payment Approval Matrix

> **Thresholds are examples only.** Replace them with figures that suit your business, bank limits and insurer's conditions.

Payment type	Value or risk category	Preparer	Verifier	Approver	Additional controls	Evidence required
Routine, established supplier, unchanged details	Low (example: under £[ ])	[Name/role]	[Not required]	[Name/role]	Duplicate check	Invoice, PO/delivery note
Routine, established supplier, unchanged details	Medium (example: £[ ] to £[ ])	[Name/role]	[Name/role]	[Name/role]	PO match	Above, plus verifier initials
High-value payment	High (example: over £[ ])	[Name/role]	[Name/role]	[Two approvers]	Call-back to supplier	Above, plus call note
Change of supplier bank details	Any	[Name/role]	[Name/role]	[Name/role]	Appendix A; first payment monitored	Appendix A
New payee	Any	[Name/role]	[Name/role]	[Name/role]	Onboarding checks; consider test payment	Onboarding file, call note
International or foreign-currency payment	Any	[Name/role]	[Name/role]	[Two approvers]	Country and currency checked	Call note, reason
Urgent or exceptional request	Any	[Name/role]	[Owner]	[Second director]	Exception log	Exception record
Payroll and tax	Scheduled	[Name/role]	[Name/role]	[Name/role]	Reconcile to schedule	Schedule, totals
[Other]						

Review this matrix every [quarter]. Last reviewed: _____ by _____.

APPENDIX E

Fraud Incident Log

Complete one per incident. Keep it factual. Do not include unnecessary personal data.

Field	Entry
Date and time detected	_____
Detected by	_____
Payment status (not sent / sent / part-sent / unknown)	_____
Suspected fraud type	_____
Amount and currency	_____
Supplier or recipient (name, account details)	_____
Payment method and date	_____
Bank contacted (name, time, person)	_____
Bank reference number	_____
Reports made (police/fraud service, regulator, insurer: date, reference)	_____
Evidence preserved (what, where)	_____
Data potentially exposed (types, whose, how many)	_____
Accounts secured (what, when, by whom)	_____
Actions taken (with times)	_____
Responsible person	_____
Follow-up date	_____
Lessons learned	_____
Corrective actions (owner, due date)	_____

APPENDIX F

Staff Verification Scripts

Short, natural, firm and fair. Adapt the wording to your own voice. None of these accuses anyone.

Script 1. Calling a supplier to verify a bank-detail change

> "Hello, this is [name] from [Business Name]. I'm calling on the number we hold for your accounts team. Could I speak to someone who deals with bank details?"
>
> *(Once connected)* "We've received a message about a change to your payment details. As we do for every change, we're confirming it by phone. Could you tell me what account you'd like us to use, and the name it's held in?"
>
> *(Write down what they say; do not read out the message's details first.)*
>
> "Thank you. Could I take your name and role? We'll complete a second check and confirm by [email/call] once it's done. We'll continue to pay the existing account until then."

Script 2. Telling a manager that an urgent payment needs independent verification

> "Before I release this, I need your help. The request changes the bank details and has a same-day deadline. Our policy is to verify those independently first. I'll call the supplier on the number in our file. Could you review it with me, and can we agree that if I can't reach them today, the payment waits?"

Script 3. Challenging a request to bypass normal approvals

> "I understand it's urgent, and I want to help. I'm not able to release this without the second approval. It isn't about trust, it's the same rule for every payment. If you can do the approval now, I'll process it straight away. Otherwise I'll raise it with [Payment Approver]."

Script 4. Reporting a payment that may already have been sent to a fraudster

To the bank (official number):

> "I need to report a payment that I believe may be fraudulent. We sent [amount] on [date/time] by [method] to account [details]. We now think the instruction was not genuine. What urgent steps can you take, and what do you need from me? Could I have your name and a reference number?"

To the owner or manager:

> "I need to tell you something now. I think we may have paid a fraudulent request. I've called the bank and have a reference number. I've kept the emails. Here is what happened, and here is what I need from you."

APPENDIX G

Knowledge Check

Ten questions. Answers and explanations follow. Aim to discuss the reasoning, not just score.

1. An email says a supplier's bank details have changed. It has the supplier's logo and is in the same thread as earlier invoices. What is the safest next step?

a) Pay the new account if the amount is small b) Phone the supplier on a number you already hold and verify c) Reply and ask the sender to confirm d) Check that the email address looks right and then pay

2. The suspicious email includes a phone number "for urgent queries". Is calling it independent verification?

a) Yes, because you spoke to someone b) Yes, if the person sounds professional c) No, the number is supplied alongside the request and could be controlled by the sender d) Only if the call is recorded

3. Which statement best describes the role of AI in invoice fraud?

a) AI is behind every invoice scam b) AI is irrelevant to fraud c) AI makes fraud undetectable d) AI can make some messages more convincing, but many scams use ordinary deception

4. A request arrives from a supplier's genuine email address, in a genuine thread, to change bank details. What follows?

a) It must be genuine b) The address can't be spoofed, so it is safe c) The account may have been compromised, so independent verification is still needed d) Only the domain needs checking

5. Who should approve a change to supplier bank details?

a) A second person who reviews the evidence, after independent verification b) The person who received the request, to keep it quick c) Anyone, as long as the supplier is long-standing d) The supplier

6. A payment you made may have gone to a fraudster. What comes first?

a) Wait for an internal investigation b) Email the fraudster to ask for the money back c) Contact your bank on its official number immediately d) Wait to see whether the supplier chases

7. Which is a behavioural warning sign?

a) A professional logo b) A polite tone c) A correct VAT number d) A request to keep a payment confidential and skip the normal approval

8. When must you notify a regulator of a personal-data breach under the GDPR framework (in general terms)?

a) Every time anyone is defrauded b) Where the breach is likely to result in a risk to individuals, generally within 72 hours of becoming aware, where feasible c) Never, if no money was lost d) Only if the media find out

9. You are a one-person business and nobody else can approve a payment. What is a proportionate alternative?

a) Skip checks because there is no one else b) Pay faster to avoid penalties c) Ask your accountant or another trusted adviser to review bank changes, or apply a 24-hour cooling-off rule d) Rely on your instinct

10. A caller who sounds exactly like your director asks for an urgent transfer. What should you do?

a) Act, because you recognise the voice b) End the call, then call the director back on a number you already hold, and follow the approval process c) Ask them to send an email from their personal address d) Transfer half the amount

Answers

1. **b.** Verification must run through a route the sender does not control. Logos and thread history are not evidence.
2. **c.** A number supplied with the suspicious request may belong to the fraudster.
3. **d.** AI may improve some messages, but the NCSC and Europol describe many established methods that do not rely on it.[2][4]
4. **c.** If a mailbox is compromised, a genuine address can send a fraudulent message. Only independent verification catches it.
5. **a.** Approval should be independent, informed by evidence from the verification.
6. **c.** Prompt contact with your bank may improve the chance of intervention. Do not wait.[1]
7. **d.** Secrecy and bypassing approvals are behavioural red flags. A logo, a correct VAT number and a polite tone are easy to copy.
8. **b.** This is the general rule, with qualifications. Not every scam is a personal-data breach, and obligations vary by country. Take advice if unsure.[8][10]

9. **c.** A second look or a delay is a proportionate alternative to a second approver.
0. **b.** A familiar voice is not proof of identity. Call back on a trusted number.

APPENDIX H

Staff Training Exercise

A 45-minute session you can run with a small team. No technology needed. **All material is fictional.**

Before the session (10 minutes). Choose one case file from Chapter 12. Print the fictional email below. Tell management in advance, so nobody is caught out in real life.

> **Fictional exercise email From:** Accounts Team accounts@fieldhouse-surveys.example **Subject:** Updated bank details, please action today Hi, we have moved bank. Please use the account below for our September invoice and update your records. We need payment by 4 pm tomorrow. Please don't call: our phones are being migrated. Thanks.

Running the session

Time	Activity
0 to 5 min	Explain the rule: *a bank-detail change is a request, not a payment instruction.*
5 to 15 min	Hand out the email. Ask each person to write down: what is odd, what they would do first, and whose number they would use.
15 to 30 min	Walk through the ten-step procedure (Chapter 5). Role-play Script 1 (Appendix F) in pairs.
30 to 40 min	Discuss one case file: first moment to pause, signs present, controls that would catch it.
40 to 45 min	Agree one improvement and one owner.

Warning signs hidden in the email: bank change; same-day-plus deadline; discouraging a phone call; generic sender and no named person; request to update records "going forward".

Debrief questions

1. Which trusted number would we use, and where is it recorded?
2. Who must approve the change here?
3. What would we say if the sender pushed back?
4. What would make it easier for someone to pause a payment?

Scoring (for discussion, not appraisal)

- ☐ Nobody replied to the email
- ☐ Everybody named a trusted source for the phone number
- ☐ The group named the second person who reviews
- ☐ The group said where the evidence is saved

Repeat with a different case file every quarter. Keep the session blame-free.

APPENDIX I

Quarterly Payment-Control Review

Review date: _____ Reviewer: _____ Next review: _____

Area	Check	Result (OK / Action)	Owner and due date
Access	Everyone with banking and accounting access still needs it; leavers removed		
Access	Multi-factor authentication on banking, email and accounting		
Supplier records	Changes this quarter each have a completed Appendix A		
Supplier records	Trusted contacts re-confirmed for top suppliers		
Approvals	Approval matrix (Appendix D) still fits current volumes and risks		
Approvals	Exceptions log reviewed; any pattern of exceptions		
Payments	New payees this quarter were verified and approved		
Payments	Duplicate-invoice register used; any duplicates found		
Incidents	Incidents and near-misses reviewed; lessons recorded (Appendix E)		
Contacts	Escalation sheet current: bank fraud line, IT contact, accountant, insurer		
Training	Staff session held this quarter or scheduled		
Policy	Anti-fraud policy reviewed and changes approved		

Overall:

Signed: _____ Date: _____

Glossary

Authorised push payment (APP) fraud. A scam in which the victim is tricked into authorising a payment to a criminal. Paying a diverted invoice is a typical example.

Business email compromise (BEC). Fraud that uses email, by impersonation or by taking over a real mailbox, to trick staff into sending money or information.

Call-back. Ending a conversation and phoning the person back on a number you already hold.

Compromised account. An email or online account that a criminal can access.

Controller. The organisation that decides why and how personal data is used.

Independent channel. A way of contacting someone that the sender of a suspicious message does not control.

Lookalike domain. A web or email address that is almost identical to a real one, such as `calderpackagng` for `calderpackaging`.

Mandate fraud / payment diversion. Fraud in which payment instructions, usually bank details, are altered so that money goes to a criminal.

Personal-data breach. A security incident that leads to the accidental or unlawful destruction, loss, alteration, unauthorised disclosure of, or access to personal data.

Processor. An organisation that handles personal data on a controller's behalf.

Social engineering. Manipulating people into acting, rather than breaking into systems.

Supervisory authority. The data-protection regulator, such as the ICO in the UK.

Three-way match. Checking that the invoice, purchase order and delivery record agree.

A Note on GDPRGard.eu

Invoice fraud sits next to a second small-business headache: knowing what to do about personal data. If this book has raised questions about breaches, supplier records or what the GDPR expects of a small business, **GDPRGard.eu** offers privacy and data-protection resources for European small businesses, including plain-English guides and practical tools.

It is a companion source of information, not a substitute for qualified legal advice, and nothing in this book depends on it. The procedures here work without it.

Companion toolkit (concept)

A downloadable companion, *The Small Business Invoice Fraud Prevention Toolkit*, is planned as editable versions of this book's templates: the supplier bank-detail change checklist, payment approval matrix, invoice verification checklist, fraud incident log, emergency response flow, a staff training exercise, and a quarterly payment-control review. It is a convenience for adapting the templates, not a replacement for professional advice, appropriate banking controls or your legal obligations.

About the Author

Zirlandia Milkovic writes practical guides that help small businesses make sense of fraud, privacy and AI. She is the founder of GDPRGard.eu. Her books focus on short procedures, clear checklists and plain English, written for people who run businesses rather than security teams.

Add or amend personal credentials before publication. This biography makes no professional claims beyond those the author confirms.

Notes and Sources

Sources were read between 25 and 28 October 2026. Where a page showed no publication date, the access date is given. Please re-check every URL and date before publishing; websites change.

1. National Cyber Security Centre (NCSC), *Business payment fraud*. Describes business payment fraud (BEC) and steps if a fraudulent payment is made. No publication date shown; accessed 28 October 2026. https://www.ncsc.gov.uk/section/respond-recover/ml-business-payment-fraud
2. Europol, *Spotlight Report: Online fraud schemes, a web of deceit* (IOCTA Spotlight), describing CEO fraud and fake invoice fraud; and Europol, *Internet Organised Crime Threat Assessment (IOCTA) 2026*, listing business email compromise among common online fraud types. Descriptions here come from Europol publication listings reviewed on 28 October 2026; the full documents should be re-read before publication. https://www.europol.europa.eu/cms/sites/default/files/documents/Spotlight-Report_Online-fraud-schemes.pdf and https://www.europol.europa.eu/cms/sites/default/files/documents/IOCTA-2026.pdf
3. NCSC, *Small organisations guide to cyber security: Spotting cyber attacks*. Accessed 28 October 2026. https://www.ncsc.gov.uk/collection/small-organisations-guide-to-cyber-security/spotting-cyber-attacks
4. NCSC, *Impact of AI on cyber threat from now to 2027*, published 7 May 2025. Accessed 28 October 2026. https://www.ncsc.gov.uk/report/impact-ai-cyber-threat-now-2027
5. NCSC, *Phishing attacks: defending your organisation*, first published 5 February 2018; the page shows a review date of 13 February 2024. Accessed 28 October 2026. https://www.ncsc.gov.uk/guidance/phishing
6. Take Five to Stop Fraud (UK Finance campaign), *Invoice and mandate fraud: business*. Accessed 28 October 2026. https://www.takefive-stopfraud.org.uk/protect-your-business/invoice-and-mandate/
7. Report Fraud (City of London Police), the national fraud and cybercrime reporting service for England, Wales and Northern Ireland, which replaced Action Fraud; Scotland reports via Police Scotland (101). Confirmed through Take Five guidance and City of London Police news reports; dates and opening hours to be re-verified on the official site. https://www.reportfraud.police.uk/
8. Information Commissioner's Office (ICO), *Personal data breaches: a guide*. Accessed 28 October 2026. https://ico.org.uk/for-organisations/report-a-breach/personal-data-breach/personal-data-breaches-a-guide/
9. European Data Protection Board, *Guidelines 9/2022 on personal data breach notification under GDPR*, version 2.0 (page dated 4 April 2023). The description of "awareness" is drawn from secondary summaries of the guidelines and must be verified against the PDF before publication. https://www.edpb.europa.eu/documents/426_en

0. Regulation (EU) 2016/679 (General Data Protection Regulation), Articles 4(12), 33 and 34 (cited from working knowledge; verify against the official text). https://eur-lex.europa.eu/eli/reg/2016/679/oj For the UK, see the UK GDPR and Data Protection Act 2018 on legislation.gov.uk.

1. Further reading on current fraud figures: UK Finance annual fraud reports (https://www.ukfinance.org.uk/) and the Payment Systems Regulator's pages on reimbursement for authorised push payment fraud (https://www.psr.org.uk/). Reimbursement rules in the UK cover some, but not all, businesses; ask your bank whether your business is eligible.